



AI-driven digital twin-based security orchestration, automation and response for critical infrastructures

Phu Nguyen¹ · Ashish Rauniyar¹ · Jone Bartel² · Jan Laufer² ·
Christos Dalamagkas³ · Klaus Pohl²

Received: 21 July 2025 / Accepted: 21 February 2026 / Published online: 9 March 2026
© The Author(s) 2026

Abstract

The more critical infrastructures (CIs) being digitized, the more vulnerable they are regarding cyber security attacks. Digitisation-leveraging technologies in the Internet of Things (IoT) and Cyber-Physical Systems (CPS) have been largely adopted for CIs, along with the Digital Twin (DT) paradigm. However, the distributed and heterogeneous nature of IoT or CPS poses significant challenges in safeguarding against diverse attack surfaces, including physical devices, network infrastructures, and third-party integration. To tackle these challenges, we propose an AI-driven DT-based security orchestration automation and response framework (SOAR4BC). Gathering system contexts from the DT in combination with security intelligence from the security tools gives us a holistic context for SOAR, which has not been seen in the existing approaches. We leverage this holistic context into the decision-making core, which utilizes advanced algorithms, like deep reinforcement learning, to generate adaptation recommendations based on incident alerts, risk assessments, and system state observations. By rigorously evaluating tampered data and distributed denial of service (DDoS) scenarios, we validate the SOAR4BC framework's efficacy in handling security incidents leveraging digital twin environments. We further demonstrate real-world applicability through false-data injection and DoS attacks on an operational electric-vehicle charging testbed, confirming the practical effectiveness of SOAR4BC in securing critical infrastructures. Together, these results establish SOAR4BC as a robust and explainable AI-driven SOAR framework that advances the use of digital twins for cybersecurity in IoT and CPS ecosystems, offering actionable contributions for both research and industrial deployment.

Keywords Explainable AI · Digital twin · SOAR · Security orchestration · Critical infrastructures · Reinforcement learning

1 Introduction

Our societies are relying on a vast array of services that are increasingly transitioning into digital ecosystems, and their susceptibility to cyber security threats becomes more pronounced (Chowdhury and Gkioulos 2021; Riggs et al. 2023). This digitization process involves the integration of advanced technologies such as the Internet of Things (IoT) and Cyber-Physical Systems (CPS), often accompanied by the adoption of the Digital Twin (DT) paradigm (Alcaraz and Lopez 2022). As systems become more interconnected and reliant on digital infrastructure, they become exposed to a myriad of security vulnerabilities. However, safeguarding these digitized systems presents a formidable challenge. The distributed and heterogeneous nature of CPS/IoT introduces complexities in defending against a wide array of attack surfaces (Sheikh et al. 2022). These attack surfaces encompass not only traditional targets such as network infrastructures and physical devices but also extend to encompass third-party integration and supply chain dependencies. Moreover, the constantly evolving landscape of security threats, coupled with the potential cascading effects of cyber attacks, further exacerbates the challenge of ensuring the security and resilience of IoT/CPS systems for CIs.

According to Microsoft, “security orchestration, automation, and response (SOAR) refers to a set of services and tools that automate cyberattack prevention and response” (Microsoft Security 2024). Microsoft differentiates between security automation and security orchestration. Security automation refers to the use of information technology to replace manual processes for responding to cyber incidents and managing security events. In contrast, security orchestration involves integrating various security and IT tools to streamline processes, thereby enhancing security automation. According to Islam et al., security orchestration encompasses the planning, integration, cooperation, and coordination of activities among security tools and experts. This approach ensures that necessary actions in response to security incidents are automated across multiple technological environments (Islam et al. 2020).

Security orchestration has the potential to become an essential aspect of securing IoT ecosystems as the complexity and scale of IoT deployments continue to increase. Security orchestration involves automating and integrating security tools, processes, and technologies to provide a more cohesive and streamlined security process. By orchestrating security across different IoT devices and edge computing systems, organizations can reduce the risk of gaps or overlaps in security coverage (Alwarafy et al. 2020). Security orchestration is important for several reasons. First, it allows organizations to respond to security threats more quickly and efficiently. Automated security workflows can identify, triage, and respond to security incidents in real time, reducing the risk of data breaches or other cyber attacks. Second, security orchestration can help organizations achieve compliance with industry and government regulations. Many regulations require organizations to implement specific security measures, and security orchestration can help ensure that these measures are consistently applied across the IoT ecosystem. Finally, security orchestration can help organizations reduce the cost and complexity of security management. By automating

security workflows and integrating security technologies, organizations can reduce the burden on security teams and achieve greater visibility into security operations (Islam et al. 2019b).

Security orchestration approaches have been reviewed in Islam et al. (2019b) that contain the integration of several security systems, and cooperative security solutions, even though not specialised for computing continuum or IoT/Fog/Edge aspects. Intrusion detection systems, network, and application layers are among the system layers that are the primary focus of current security orchestration, automation, and response (SOAR) techniques. However, considering the computing continuum, there is a noticeable lack of more holistic SOAR techniques for multi-layered IoT/CPS systems (Nguyen et al. 2025). A recent systematic review of SOAR approaches for IoT/CPS systems shows some main gaps in the state of the art (Islam et al. 2019b): (i) IoT/CPS systems require a more holistic SOAR approach that addresses cross-layer architectural elements. Most existing solutions focus on Edge and Cloud, with insufficient attention to the IoT/Things layer; (ii) AI/ML improves automation, but it is insufficient in addressing explainability and cross-layer/system/domain issues; and (iii) the incorporation of digital twin solutions into SOAR frameworks is still in its early stages. Few studies address the combined use of AI, Digital Twins, and DevSecOps in SOAR, indicating a promising research direction. Moreover, existing works have not demonstrated an integration of Digital Twin with SOAR in an explainable AI framework for CI.

Building on the state of the art in SOAR, this paper introduces a novel digital twin-based Security Orchestration Automation and Response framework for Business Continuity (SOAR4BC). This framework leverages the contextual insights provided by the DT, integrating them with security intelligence gleaned from various security tools. Context can be considered as a key for adapting to user needs (Tigli et al. 2011), which includes more automated security orchestration while following the human-in-the-loop paradigm. SOAR4BC aims to provide comprehensive protection for digital twin-based IoT/CPS systems by adopting a holistic approach to security orchestration for CIs.

Smart security orchestration for policy-based access control typically focuses on the edge layer. This includes implementing a Machine Learning agent (ML-agent) to detect and store threat patterns/data and to orchestrate and automate the control of deployment and (re)configuration of all the security requirements. The focus will be on implementing orchestration on the edge layer and seeing how we can improve the flexibility and adaptability of access control policies. Emphasizing edge layer orchestration, SOAR4BC seeks to improve the flexibility and adaptability of access control policies, optimize resource utilization, and minimize latency by leveraging edge computing capabilities.

In the evaluation of SOAR4BC, we investigate the following Research Questions (RQ)s:

- ***RQ1. To what extent can the integration of digital-twin-driven system context enhance the detection, analysis, and handling of security incidents within IoT/CPS-based critical infrastructures?***

- **RQ2.** *How effectively can the AI-driven SOAR4BC framework, leveraging DRL-generated playbooks and explainable reasoning, automate incident response while maintaining transparency for human operators?*
- **RQ3.** *To what extent can SOAR4BC maintain robustness and practical applicability when deployed in real-world CI environments, such as EV charging infrastructures, under different attack scenarios?*

Through experimental evaluation, including the analysis of tampered data and distributed denial of service (DDoS) attack detection and real-world testing on an electric vehicle (EV) charging station testbed, this paper substantiates the efficacy and reliability of the SOAR4BC framework. The validation provided serves as a compelling proof of concept, demonstrating the SOAR4BC framework's ability to detect and respond to security policy violations within simulated DT environments. Moreover, this work offers valuable insights into the convergence of DT technology and cybersecurity, shedding light on the unique challenges and opportunities inherent in DT-based systems.

In principle, this paper presents novel contributions in leveraging DT within the SOAR framework, specifically tailored for IoT/CPS systems for CIs. Some initial results of this work have been presented in Nguyen et al. (2025). The primary contributions of this paper as an extension of Nguyen et al. (2025) are outlined as follows:

- **Integration of DT:** In Nguyen et al. (2025), we initiate our demonstration of the integration of DT within the security domain, mainly focusing on IoT/CPS systems. This paper presents how, by harnessing the capabilities of digital twins, we establish a realistic and dynamic data-driven system context in combination with a security context.
- **Development of SOAR4BC Framework:** In Nguyen et al. (2025), we introduce the SOAR4BC framework, uniquely designed to address security challenges within DT-based systems. The focus in Nguyen et al. (2025) was on the enforcement of security orchestration, without AI-driven decision-making presented in this extended version. This extended AI-driven framework facilitates automated incident detection, analysis, and response orchestration, ensuring robust security measures are in place to safeguard the integrity of the system.
- **AI-driven decision making with DRL:** Leveraging Deep Reinforcement Learning (DRL), we are able to generate CACAO v2-compliant playbooks (Jordan and Thomson 2023) handling incidents in real-time.
- **Explainability:** To support the human-in-the-loop paradigm, we focus on making our components explainable to the users by providing an individualized natural language chat interface capable of explaining the preferred adaptations and reasoning in a multi-round fashion.
- **Experimental Evaluation and Validation:** Through rigorous data tampering and DDoS attack experimental evaluation and demonstration, we validate the efficacy and reliability of the SOAR4BC framework in detecting and responding to security policy violations within the DT-based systems. In Nguyen et al. (2025), we demonstrate our initial SOAR4BC solution using the training factory Industry 4.0. This extended version presents our more thorough evaluation of not only the

training factory Industry 4.0 but also real-world EV charging station scenarios. Our experiments provide empirical evidence of the SOAR4BC framework's effectiveness in enhancing security posture and mitigating potential threats.

- **Real-world Application Testing:** Additionally, we conducted false data injection and DoS attacks on a real EV charging station testbed infrastructure to further demonstrate the practical effectiveness of the SOAR4BC framework. This real-world experimentation highlights the framework's applicability in securing CIs beyond simulated environments.
- **New Insights into DT Security:** Our research offers new insights into the intersection of DT technology and cybersecurity, shedding light on the unique challenges and opportunities presented by DT-based IoT/CPS systems. We contribute to the growing body of knowledge in this emerging field, paving the way for future advancements and innovations.

The remainder of this paper is structured as follows. Section 2 gives some key concepts used in this paper. We present a motivational example in Section 3. Our AI-driven digital twin-based SOAR approach is presented in Section 4. We present our experiments and results in Section 5. Related works are discussed in Section 6. We conclude the paper in Section 7 along with some future works.

2 Background

In this section, we provide the definitions of some key concepts.

2.1 Security orchestration

Microsoft has distinguished security automation and security orchestration (Rios et al. 2023): “Security Automation is the use of information technology in place of manual processes for cyber incident response and security event management” and “Security orchestration is the integration of security and information technology tools designed to streamline process and drive security automation” Microsoft Security (2024).

C. Islam et al., “Security Orchestration is the planning, integration, cooperation, and coordination of the activities of security tools and experts to produce and automate required actions in response to any security incident across multiple technology paradigms.” Islam et al. (2019b) Security Orchestration is a core concept to our approach (cf. Section 4.4), as it enables fully automatic threat mitigation for complex systems, e.g., Critical Infrastructure (CI). In order to orchestrate the needed actions, the processes and rules need to be clearly defined. We rely on CACAO v.2 playbooks to hold these information.

2.2 CACAO security playbook v.2

Organizations must identify, look into, stop, mitigate, and fix problems in cyber-relevant time to protect against threat actors and their strategies, methods, and pro-

cesses. To do this protection, organizations must determine, develop, record, and test the orchestration procedures required to accomplish these results. When combined, these actions provide a cyber security playbook that may be utilized to safeguard individuals, data, networks, and organizational systems. Playbook is “a standard set of operational procedures (playbook) to be used in planning and conducting a cyber-security vulnerability and incident response activity.”¹

The schema and taxonomy for collaborative automated course of action operations (CACAO) for cyber security playbooks are defined in the CACAO playbook specification version 2 (Jordan and Thomson 2023), which also outlines how these playbooks can be developed, recorded, and disseminated in a methodical and uniform manner across organizational boundaries and technological solutions.

We automatically generate CACAO v.2-compliant playbooks from a set of possible mitigation actions in real time, which can then be consumed by the orchestrator to automatically respond to threats (cf. Section 4.2). Playbooks with a fixed syntax enable us, to automatically respond to threats in a clear, transparent, and adequate manner. This automatic generation is powered by Deep Reinforcement Learning (DRL), which we detail in the following Section.

2.3 Deep reinforcement learning

(Online) Reinforcement Learning (RL) is increasingly used to manage uncertainty in dynamic, open-world environments. In contrast to traditional approaches that rely on static design-time logic, RL enables systems to learn optimal decision-making policies by interacting continuously with their environment. This interaction-driven learning allows systems to adapt based on new information that emerges at runtime, supporting flexible and responsive behavior in changing conditions.

Deep Reinforcement Learning (DRL) extends RL by using neural networks to represent learned policies, rather than relying on tabular formats. This enables DRL to generalize to previously unseen states, making it suitable for problems with large or continuous input spaces and allowing proper adaptations to unforeseen business continuity risks.

As Deep Reinforcement Learning (DRL) effectively functions as a black box to stakeholders, explainability is required. Specifically, we rely on eXplainable Reinforcement Learning - Decomposed Interestingness Element (XRL-DINE), an explainability technique using DRL while providing local explanations for the otherwise black-box DRL-agent. XRL-DINE aggregates well-known eXplainable Artificial Intelligence (XAI) approaches Reward Decomposition and Interestingness Elements to generate so-called Decomposed Interestingness Elements (DINEs). These DINEs can further be used by our natural language conversational XAI platform Chat for eXplainable Artificial Intelligence (Chat4XAI) to provide easy-to-understand, interactive explanations to relevant stakeholders.

¹ <https://www.whitehouse.gov/briefing-room/presidential-actions/2021/05/12/executive-order-on-improving-the-nations-cybersecurity/>

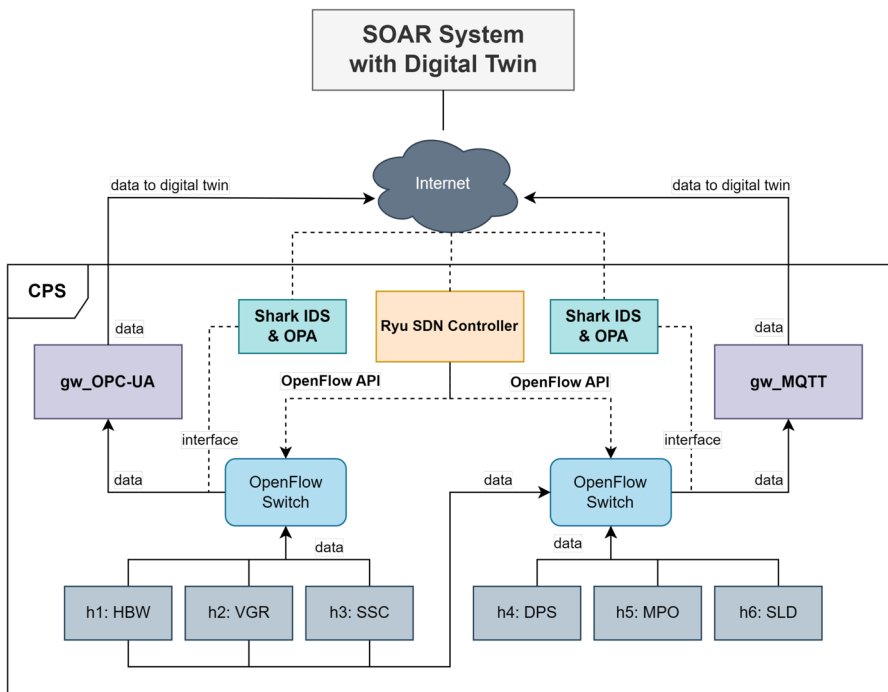


Fig. 1 The factory industry 4.0 connected to a SINTEF digital twin (SINDIT) (Nguyen et al. 2025)

3 A motivational example - training factory industry 4.0

In this section, we present a training factory as a representative example of a Digital Twin-based CPS/IoT system. We used Fischertechnik© Training Factory Industry 4.0 24V (Fischertechnik 2023). This factory replicates an ordering, manufacturing, and delivery process using several pieces of equipment like an automated High Bay warehouse. The Factory Industry 4.0 has been connected to a DT implemented as an instance of the DT platform called SINDIT.² SINDIT is synchronised in real-time with the physical assets and contains all pertinent data about the assets from the connected Factory Industry 4.0.

Within the SINDIT environment, we interface with six distinct components (h1-h6 in Fig. 1), each playing a pivotal role in the simulated industrial processes:

- **Highbay Warehouse (HBW):** The HBW serves as a storage facility within the factory, housing raw materials and finished products.
- **Robot (VGR):** This component embodies the automation aspect of the factory, executing tasks such as material handling and product assembly.
- **Sensor Unit (SSC):** The SSC encompasses sensors dispersed throughout the factory, collecting real-time data on various parameters such as temperature, pressure, and machine statuses.

² <https://github.com/SINTEF-9012/SINDIT>

- **Delivery and Pickup (DPS):** Responsible for managing the logistics of product transportation within the factory premises, the DPS ensures a seamless movement of goods between different stages of production.
- **Multi-Processing Station (MPO):** The MPO represents a versatile processing unit capable of executing multiple tasks concurrently, enhancing production efficiency.
- **Sorting Line (SLD):** This component oversees the sorting and categorization of products based on predefined criteria, streamlining the final stages of production.

The Training Factory Industry 4.0 provides many time-series outputs from the physical assets that are communicating using OPC-UA or MQTT via two corresponding gateways. Some representative security mechanisms have been deployed in the connected Factory Industry 4.0. We have utilized Mininet as a core component of our software-defined networking (SDN) infrastructure. This allowed us to create a virtual network environment mirroring the training factory's network, granting us extensive control over switch and firewall configurations at an application level for managing network security (Neupane et al. 2018). Ryu³ is used as an SDN controller, which has a REST Firewall application. It is a Python script written by the Ryu developers that allows us to create, modify, and delete firewall policy rules remotely through REST calls. While the SDN controller allows us to manage flow control of the network, it does not report events that happen in the network. Therefore, a basic Intrusion Detection System (IDS) has been deployed to alert the SOAR system to security breach events. This system is named Shark IDS. To control the access policies that the Shark IDS will utilize, we deployed an Open Policy Agent (OPA)⁴ server that will run alongside the Shark IDS. Instead of having hard-coded, custom rules written directly into the Shark IDS, it will request authorization from OPA and receive a response for handling policy access control. It can then forward any security breaches to the SOAR system, which can handle the incident response.

This Factory Industry 4.0 is a representative example of critical infrastructures in many different domains, such as manufacturing (Isaja et al. 2023), energy (Bharatee et al. 2022), and healthcare, in which DT technology is widely used, and security is of paramount importance (Rajmohan et al. 2022). Industry 4.0, characterized by the integration of CPS, IoT, and smart automation, faces unique and complex cybersecurity challenges such as ransomware attacks, data tampering, supply chain attacks, distributed denial of service attacks, IoT device exploitation, and man-in-the-middle attacks. Therefore, it is vital that there is a systematic SOAR approach to leverage the DT as well as the security tools to enhance security automation with human-in-the-loop in addressing the threats and incidents. This example in particular highlights the characteristics of modern CI ecosystems and demonstrates the need for a framework like SOAR4BC, which integrates DT-driven context, automated AI-based decision making, and explainability to support secure and resilient operations.

³ <https://ryu-sdn.org/>

⁴ <https://www.openpolicyagent.org/docs/latest/>

4 AI-driven digital twin-based SOAR approach

In this section, we present our SOAR4BC approach, which leverages the DT of actual systems to provide a holistic context for security orchestration, automation, and response. SOAR4BC is connected to other components of the DYNABIC framework (Rios et al. 2023), providing necessary information such as security alerts via a Kafka bus. As seen in Fig. 2, it receives inputs from AWARE4BC (not presented in this paper) for incident details, the DT called MADT4BC (not presented in this paper) for system information, RISK4BC for risk analysis data, and CTI4BC for external incident information. SOAR4BC is also linked to AVATAR4BC to provide assistance to human operators. More details on these other modules can be found in Nguyen et al. (2023), Rios et al. (2023). In this paper, we mainly focus on the inner components of SOAR4BC, as presented in the following subsections.

Algorithm 1 AI-driven digital twin-based SOAR approach.

Input: Incident data, System state data, Risk analysis, AWARE4BC and/or CTI data
Output: Generated CACAO v2 Playbook with optimal response actions and a list of response actions executed

Initialize:

- ┌ Connect to Kafka bus to receive data streams;
- ┌ Load system state and historical data from Knowledge Base;
- ┌ Set up the connection to the Digital Twin (DT) environment;

Tools Integration Unit

- ┌ **while** incident data received from security tools **do**
- ┌ Extract *Tool-specific Context, Environment Context, Security Context*;
- ┌ **if** incident type matches predefined security events **then**
- ┌ ┌ Forward contextual data to **Adaptation Strategy**;

Adaptation Strategy

- ┌ **if** triggering event is detected **then**
- ┌ Retrieve system state from DT and parse it into observations;
- ┌ Use Deep Reinforcement Learning (DRL) agent to assess system state;
- ┌ Select optimal adaptation workflow based on reward function;;
- ┌ • Consider both short- and long-term cost evaluation;
- ┌ • Possible action space extracted from Knowledge Base;
- ┌ **if** adaptation workflow is selected **then**
- ┌ ┌ Format workflow as CACAO v2-compliant playbook;
- ┌ ┌ Forward playbook to **Orchestration Unit**;

Orchestration Unit

- ┌ **while** playbook received **do**
- ┌ Parse playbook and verify workflows;
- ┌ Retrieve corresponding actions from Knowledge Base;
- ┌ Generate streamlined response workflow;
- ┌ Forward response to **Action Automation Unit**;

Action Automation Unit

- ┌ **while** actions are pending **do**
- ┌ Execute response actions through relevant security tools via Tools Integration and/or MADT4BC;
- ┌ Update Knowledge Base with action status and feedback;
- ┌ Log actions on SOAR4BC Dashboard for operator review;

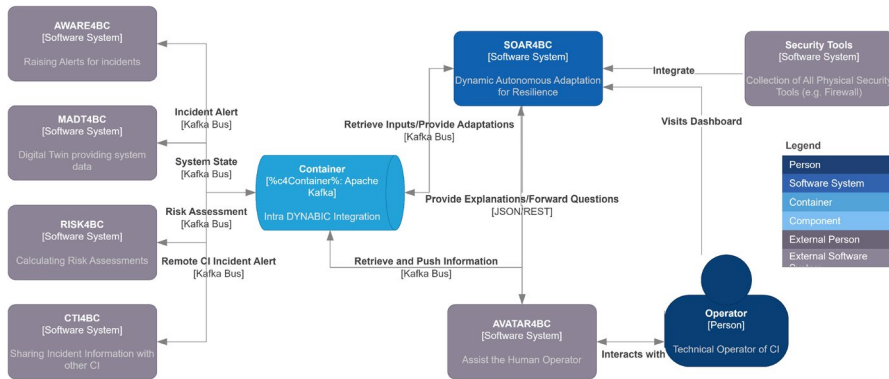


Fig. 2 High-level component view of SOAR4BC (Nguyen et al. 2025) integrated in the DYNABIC framework

In our work, the environment, tool-specific, and security contextual knowledge provide comprehensive insights for SOAR. By integrating these elements into a unified knowledge service, we streamline and simplify the process of accessing, managing, and utilizing relevant information in security analysis and orchestration. This approach minimizes redundancy and inconsistencies, thereby enhancing the efficiency of security operations.

Figure 3 shows the inner components of the SOAR4BC solution. The **Tools Integration** unit (cf. Section 4.1) has integrated with all available security tools deployed in the physical system. This integration allows enriching the **Knowledge Base** (cf. Section 4.3) with knowledge graphs that represent the complex and dynamic relationships among security aspects such as the protected assets and the security tools, as well as their capacity. The “raw” security context is provided directly by the security tools via this integration, while the “intelligent” security context can be provided by external components of the DYNABIC framework such as AWARE4BC providing intelligence on the incidents, or RISK4BC providing risk data via the Kafka bus. The system context is provided in real-time by MADT4BC, the digital twin solution, via the Kafka bus. Note that the **Knowledge Base** is (continuously) enriched with the system data from MADT4BC, e.g., the system architecture of the physical system is stored as a knowledge graph, in which each node also contains data associated with it. This system context data provided by MADT4BC and security context data provided by the **Tools Integration** unit, as well as AWARE4BC or RISK4BC, provide a holistic context to the decision-making and enforcement components of SOAR4BC.

The details of SOAR4BC operation can be seen as Algorithm 1. To put it simply, SOAR4BC decides on the best possible security adaptations using Deep Reinforcement Learning (DRL) (cf. Section 4.2) based on the holistic security and system context and orchestrates them (cf. Sections 4.4 and 4.5). Adaptations can either be executed automatically, i.e., without human interference, or by following the human-in-the-loop paradigm. The degree of automation depends on the specific use case and action space. The playbook generation is needed by the Orchestration Unit, Tools Integration Unit and Action Automation Unit to streamline adaptations in response to incidents.

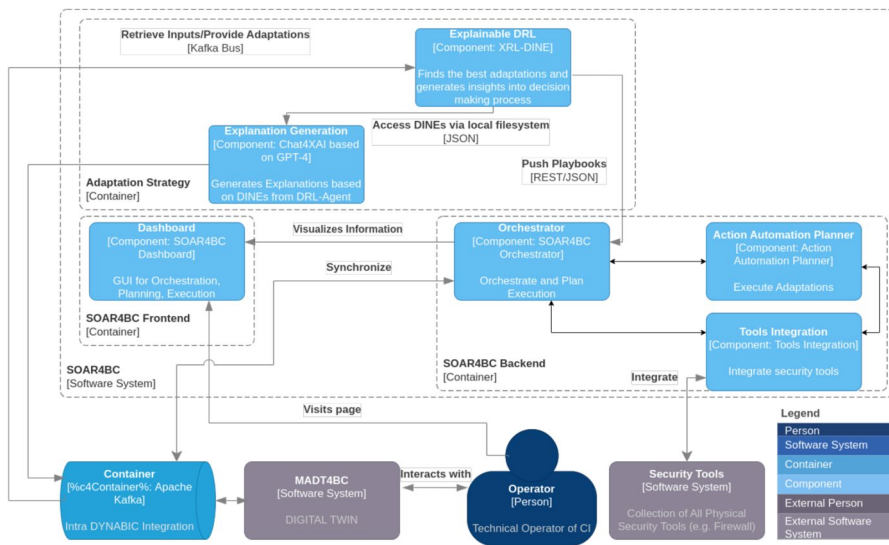


Fig. 3 Simplified digital twin based SOAR4BC framework. Minor components, e.g., data processing components, were left out for easier understanding

4.1 Tools integration unit

A key component of SOAR4BC is the Tools Integration unit, which harmonizes the activities of the existing security tools of the system (Islam et al. 2020a). Security tools are our generalized term for tools that will protect the physical system. This could be firewalls, access control tools, intrusion detection systems, etc. They have been deployed to protect the system. We assume that every security tool or service offers multiple security capabilities. When analysing a security operation or event occurring on an entity of a DT and triggered by a security service, several factors must be considered in specific runtime contexts.

- **Tool-specific Context:** The output (e.g., decision and metrics) within the specific context of the security tool, such as functionality, performance, configuration, input source, and input quality.
- **Environment Context:** The entity within the DT context, including its relationships with other entities, such as direct network connections to other entities or being operated by a specific user.
- **Security Context:** The operation within multiple security aspects, such as whether the entity is currently experiencing unauthorized access or has been detected with malware.

The Tools Integration Unit acts as the end-point for tools in the SOAR component. This could, for instance, be an API gateway or other forms of end-points for tools to communicate via a connection from the actual system. Another example is when a security breach gets caught by a tool, it gets forwarded to the Tools Integration

Unit. The data then gets forwarded to the data processing unit (Knowledge Base, cf. Section 4.3), which in turn conducts semantic integration of the tools' outputs and processes it for orchestration (Orchestration Unit, cf. Section 4.4).

4.2 Adaptation strategy

The primary objective of the *Adaptation Strategy* is generating CACAO (v2) compatible playbooks, that encapsulate the optimal adaptation workflow for a CI when a triggering event occurs. These triggering events can include incident alerts, simulated incident alerts, or remote alerts. Triggering events originate from a variety of sources and tools, such as other tools based on the Digital Twin (DT) (cf. DYNABIC Rios et al. 2023) or similar Critical Infrastructures (CIs). Upon receiving a triggering event, the *Adaptation Strategy* leverages a DRL-agent to assess the current system state and find the best possible adaptation workflow. For this purpose, the DRL agent utilizes the continuously collected data from the Digital Twin (DT) as its observation space. Based on the observation space, the DRL agent decides on the most optimal adaptation workflow from the action space, considering short and long-term costs. The action space includes various security and resilience mechanisms implemented by physical security tools that are integrated into the physical system via the Tools Integration Unit Section 4.1. The reward function specifies the concise costs and consequences that the DRL agent takes into account. Since we use XRL-DINE as an explanation technique for our DRL, we decompose the reward function into separate, semantically annotated channels. Typically, these channels relate to individual, possibly conflicting, business goals. This ensures the system can respond dynamically and effectively to various triggering events, considering different dimensions of business continuity. After choosing the best adaptation workflow, i.e., the most suitable action from the action space, it is transcribed to a CACAO v2-compliant playbook, which can be automatically orchestrated by the respective Orchestration Unit (cf. Section 4.4). The transcription of the optimal adaptation strategy to a CACAO-compatible playbook is done via a template-based approach. For each possible use case, the associated relevant static data, e.g., identities and agents, in the associated template are complemented with live data, e.g., specific IP addresses, timestamps, and external references. Possible adaptation workflows from the action space are mapped to their steps involved in orchestrating that workflow. Finally, the selected workflow, i.e., all individual steps belonging to that adaptation workflow, are transcribed as action steps and embedded in between a default start step and end step. The finalized playbook is further processed by the orchestrator (Section 4.4). After orchestration and execution, the (online) DRL agent continuously incorporates feedback, i.e., the changed system status, from the CI to improve impact evaluation.

The exact reward function, action, observation space, and goals depend on the application's use case and need to be defined accordingly. Methodologically, to define the observation space, action space, and reward design, we first model the relevant business goals for the intended application. From these goals, we derive the reward channels and then assess which available data can support these channels and their calculation. The necessary data is then included in the observation space. Additionally, technically feasible, relevant data is integrated into the observation space,

as well. The action space is logically constrained by the existing tools that have been integrated by the Tools Integration Unit (cf. Section 4.1). We provide the used reward function, action space, and observation space for the *EV Charging Infrastructure* use case in Section 5.2 for a better understanding. Additionally, all relevant source code is publicly available.⁵ A CACAO v2-compliant playbook is represented in JSON format (cf. Listing 1) and has a similar structure regardless of the triggering event, the leading preamble holds general data like ID, type, creation date and others. Generally, each playbook holds the id of the triggering event (as its external reference) and its own id, which is structured as “playbook_<incident_id>”. After the preamble and external references, workflows are defined. There are always multiple possible workflows with different rankings. The higher the ranking, the more preferred this workflow is over the others. Currently, we use a simple version in which each playbook is mapped to a single adaptation workflow based on the pre-defined action space stored in the **Knowledge Base** (cf. Section 4.3).

Listing 1 An exemplary playbook

```

1 {
2   "type": "playbook",
3   "spec_version" : "cacao-2.0",
4   "id" : "playbook--0392cbeb-bd2a-4b03-80f4-97e54be0c1a8",
5   "name" : "SOAR4BC Playbook", ...
6   "workflow_start" : "start--9339c898-3427-4da0-8b64-c3d761627cbf",
7   "action--a74d5427-5e97-42df-94e3-95923e49da16": {
8     "name": "Check Violation",
9     "description": "Check for violations in data packets of the SINDIT
10      toy factory digital twin ",
11     "on_success" : "if-condition--9c654f27-a3ff-4f12-8502-853e2c5c17a5" ,
12     ...
13     "type" : "action" ,
14     "commands" : [
15       {
16         "type" : "http-api" ,
17         "description" : "OPA checks for policy violation for data
18          tampering" ,
19         "version" : "1.0" ,
20         "playbook_activity" : "analyze-collected-data"
21       } , ...
22     ] , ...
23     "if-condition--9c654f27-a3ff-4f12-8502-853e2c5c17a5" : {
24       "name" : "if_condition" ,
25       "step_extensions" : {
26         "0" : [
27           "extension-definition--418ee24c-9cb1-46d9-afa5-309e01aabc7f"
28         ] , ...
29       } ,
30       "type" : "if-condition" ,
31       "condition" : "No Value" ,
32       "on_true" : "playbook-action--80dda560-21a0-4157-85e9-d93be5e6a1da" ,
33       "on_false" : "action--a74d5427-5e97-42df-94e3-95923e49da16"
34     } ,
35     "playbook-action--80dda560-21a0-4157-85e9-d93be5e6a1da" : {
36       "name" : "Disable Communication" ,
37       "description" : "Disable firewall so that the incoming data from that
38        host will be blocked" ,
39       "on_success" : "action--407f8ae0-d358-48f2-b6e0-7e734946189c" , ...
40     }
41   }
42 }
```

⁵ <https://gitlab.com/dynabic/soar4bc>

Tackling the black-box nature of DRL (cf. Section 2), *Adaptation Strategy* incorporates the XAI technique *XRL-DINE* (Feit et al. 2022) instead of plain DRL. This XAI technology facilitates the generation of DINEs,⁶ providing different, semantically annotated, reward channels. Each reward channel pertains to a certain business goal, allowing more fine-grained interpretability of the rewards and, hence, of the reasoning of the DRL agent. These DINEs are the basis for natural language multi-round explanations through the Chat4XAI (Metzger et al. 2023) platform, providing clear and understandable insights into the decision-making process of the black-box DRL. Chat4XAI is essential to provide transparency and explainability to the CI operator. Furthermore, Chat4XAI allows SOAR4BC to build on the human-in-the-loop paradigm by giving the operator understandable individual natural language explanations. As there is no silver bullet explanation, Chat4XAI provides explanations in a multi-round conversation, tailoring the explanations to the operator's needs. Human-in-the-loop is crucial for (i) validating and (ii) taking further (manual) actions based on the actions suggested by the DRL agent, especially for CIs.

4.3 Knowledge base

The Knowledge Base is a back-end service (loosely attached to the Orchestrator, cf. Section 4.4) that is responsible for receiving, processing, and structuring data. One of the main functionalities that the Knowledge Base provides is interoperability and interpretability, mostly based on Knowledge Graphs. We incorporate existing knowledge graphs from multiple security aspects. We incorporate existing knowledge graphs from multiple security aspects. A knowledge graph is a structured data model that is used to record information about things, their characteristics, and their relationships. It is widely utilized in many different fields that need to represent and enrich knowledge (e.g., Wikidata Vrandečić and Krötzsch 2014 and YAGO Pellissier Tanon et al. 2020). Knowledge graphs have been used to help in DT model representation and data integration (e.g., SINDIT Waszak et al. 2022). Knowledge graphs are used in cybersecurity to describe and depict the intricate connections across individuals, devices, apps, threats, vulnerabilities, and security measures (Sikos 2023). Information from both security tools and the digital twin can be either inconsistently structured or unstructured data. Processing this heterogeneous data such that it can be used by the Orchestration Unit is the key focus of the Knowledge Base.

4.4 Orchestration unit

The Orchestrator is responsible for receiving the processed data forwarded and orchestrating the respective security response. Hence, it should streamline the data it gets into a proper workflow and determine the appropriate course of actual actions based on the playbook. In our architecture, the Orchestration Unit receives processed data from the Tools Integration Unit (Section 4.1), the actual CACAO playbook from the Adaptation Strategy (Section 4.2) and more contextual data if needed from the Knowledge Base Section 4.3 to instantiate the actual operational procedures (from

⁶An exemplary Decomposed Interestingness Element (DINE) can be found [here](#)

the playbook) into actual tasks by leveraging the existing tools/actuators in the actual system. After instantiating such actual operational procedures, the Orchestrator communicates with the Action Automation Planner Section 4.5 to trigger all the actual operational procedures.

4.5 Action automation unit

The Action Automation Unit will automate the execution of incident response processes and keep track of the tasks being executed. An interactive dashboard for operators also exists for effective visualization and transparency.

The Action Automation Planner receives information from the Orchestrator and is responsible for automating the response. It automates the forwarding of the action to the relevant unit to which it is connected. In our architecture, this response is forwarded to the Tools Integration Unit (cf. Section 4.1), which in turn forwards the action to the relevant security tools and services. The Action Automation Planner directly accesses the parts of the Tools Integration Unit, which are associated with the relevant physical security tools.

The Dashboard acts as a visual platform for both the Orchestrator and the Action Automation Planner. It also displays information about the system infrastructure through the DT. The flow and state of data of the dashboard are updated by changing the data in the Knowledge database directly. This is advantageous for maintainers, as it simplifies access to the data drastically. The DT solution provides a better overview of the physical system for multiple contexts. Hence, the Dashboard can present the execution status of playbooks along with the relevant infrastructure components retrieved from the DT.

5 Experimental results

We conducted experiments on two common security scenarios, i.e., Data Tampering and DDoS, first on the SINDIT network behaviors and security protocols within the Training Factory Industry 4.0 (Section 5.1), and then on a real electric charging station (Section 5.2). The Data Tampering and DDoS scenarios were chosen as they reflect the most common and high-impact cyber threats targeting integrity and availability, respectively. These scenarios are broadly applicable across multiple domains in our project, allowing us to demonstrate the generalizability and robustness of SOAR4BC. Figure 4 shows two representative playbooks that adhere to the CACAO v2 standard⁷, ensuring interoperability and compliance with industry best practices.

5.1 Training factory industry 4.0

In this section, we present our experiments on the Training Factory Industry 4.0 that was introduced earlier in Section 3.

⁷ <https://github.com/opencybersecurityalliance/cacao-roaster>

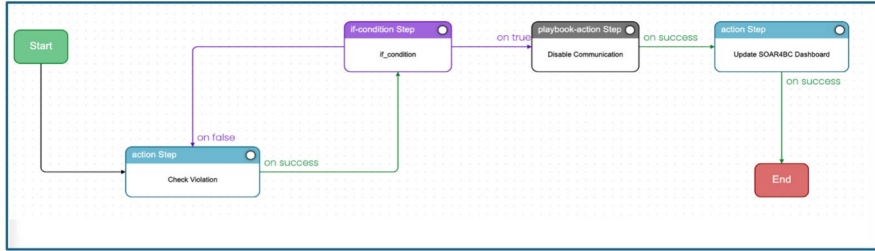
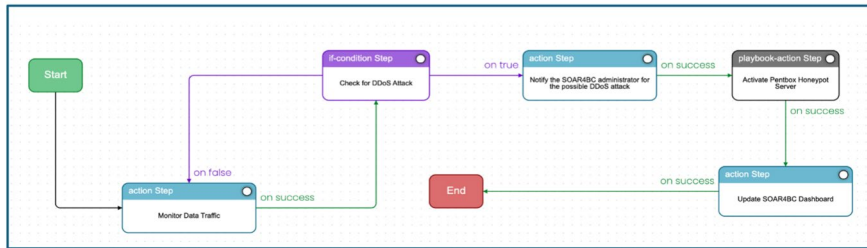
Data Tampering**DDoS Detection**

Fig. 4 SOAR4BC CACAO playbooks for data tampering and DDoS attack (Nguyen et al. 2025)

5.1.1 Data tampering scenario

In our first experimentation, we delve into the ramifications of security policy breaches such as “Data Tampering”. Specifically, we simulate instances where components in the factory environment transmit data violating established security protocols, prompting our SOAR4BC system to enact appropriate countermeasures.

To enable security policy violations in our experiments, we configured Mininet within VirtualBox 7.0. We integrated the Ryu controller with the firewall’s API to establish firewall functionalities within the network environment. We incorporated a Shark-based IDS to detect data tampering attacks by monitoring network traffic and evaluating the integrity of transmitted data against predefined security policies. Specifically, the IDS inspects packet payloads to detect unauthorized modifications, and it uses the Open Policy Agent (OPA) to enforce rules on expected data values and formats. A policy violation is triggered when the data does not conform to the OPA-defined constraints, such as altered sensor readings or manipulated control commands. Upon detecting such anomalies, the IDS communicates the violation to the SOAR4BC system via a RESTful interface.

SOAR4BC swiftly detects anomalies indicating potential data tampering because of the violation of the policy in OPA. Once an anomaly is flagged, the system verifies the integrity of the affected data and ensures any deviations are promptly assessed. Following verification, SOAR4BC orchestrates remediation steps based on the CACAO v2-compatible playbook (as shown in Fig. 4) generated by the DRL agent. In the Data Tampering scenario, the optimal playbook strategy involved isolating the affected device within the DT by reconfiguring the underlying SDN

controller, specifically, updating flow rules to block all incoming and outgoing traffic from the compromised node to prevent further tampering and allow for a thorough investigation.

Our SOAR4BC system assumes a crucial role in managing access control rules within OPA and orchestrating responses to detected security incidents. As shown in Fig. 5, upon detecting breaches, the SOAR system dynamically updates firewall policies managed by the Ryu SDN Controller to mitigate threats swiftly. To visualize and analyze data from our experiments, we utilized Neodash as a dashboard solution, interfacing directly with the Neo4j database. Neodash offers interactive visualization of toy factory components, switches, and gateways, enhancing visibility into network topology. The dashboard, as shown in Fig. 6, aggregates data from various sources, including SOAR responses, DT simulations, and host quarantine status, providing network and security operators with a comprehensive view of the network environment for informed decision-making and incident response.

5.1.2 DDoS scenario

Our second experimental evaluation focuses on a DDoS attack and shows how SOAR4BC can orchestrate two different response security mechanisms.

Backup gateway strategy Figure 7 shows the scenario of leveraging a backup gateway in the response. We have the HBW, VGR, and SSC sending data to the OPC-UA gateway. At some point during the scenario, the HBW and VGR get infected by a botnet, which will initiate a DDOS attack towards the OPC-UA gateway. Using information about the packet count sent towards the gateway, we can create

```
soar — python soar.py 192.168.56.6 — 80x24

[{"switch_id": "0000000000000001", "command_result": [{"result": "success", "details": "Rule added. : rule_id=7"}]}]
[{"switch_id": "0000000000000001", "command_result": [{"result": "success", "details": "Rule added. : rule_id=8"}]}]
[{"switch_id": "0000000000000001", "command_result": [{"result": "success", "details": "Rule added. : rule_id=9"}]}]
[{"switch_id": "0000000000000001", "command_result": [{"result": "success", "details": "Rule added. : rule_id=10"}]}]
[{"switch_id": "0000000000000001", "command_result": [{"result": "success", "details": "Rule added. : rule_id=11"}]}]
[{"switch_id": "0000000000000001", "command_result": [{"result": "success", "details": "Rule added. : rule_id=12"}]}]
{}

<Response [200]>
[EVENT HANDLER] New Data Captured
[ORCHESTRATOR] Getting Playbook Rule
[ACTION AUTOMATOR] Automating Response, Updating Dashboard
[FIREWALL SERVICE] Disabling Communication From Host 10.0.0.6
[{"switch_id": "0000000000000001", "command_result": [{"result": "success", "details": "Rule deleted. : ruleID=7"}]}]
[{"switch_id": "0000000000000001", "command_result": [{"result": "success", "details": "Rule deleted. : ruleID=8"}]}]
[]
```

Fig. 5 SOAR4BC inspecting for data tampering and orchestrating response

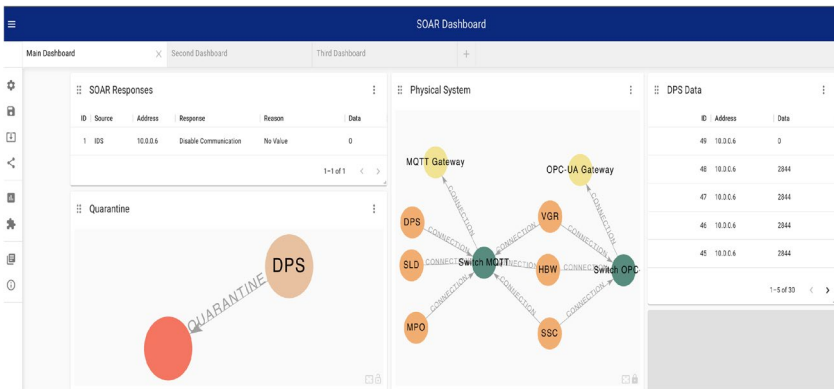


Fig. 6 SOAR4BC dashboard for data tampering incident visualization and response

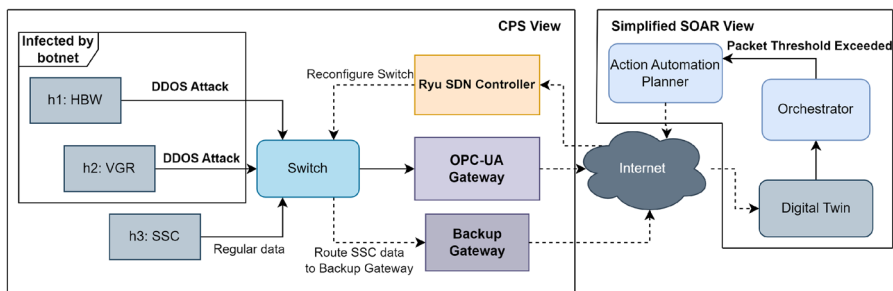


Fig. 7 Backup gateway strategy

a response for the DDOS attack, isolating the infected hosts and rerouting traffic from the SSC device towards a backup gateway so that the non-infected device can continue sending data.

The result from this evaluation can be seen in Fig. 8, where we show the packet count per cycle on the OPC-UA gateway. At **point 1**, the HBW gets infected by the botnet and initiates a DDOS attack towards the gateway. We see that the traffic increases quite a lot, but it is still under the threshold we have put in place on the gateway. At **point 2**, the VGR initiates its DDOS attack towards the gateway, and a SOAR response gets triggered, where the infected devices get isolated, and the remaining device has its traffic rerouted to the backup gateway, meaning no new traffic will enter the old gateway.

We have a backup gateway in order to ensure business continuity. With a DDoS attack, there can often be lingering effects of the attack for a while as the system tries to recover from an unexpectedly large amount of packets going through it. We can ensure that non-infected devices can continue their operations without getting halted by deploying a backup gateway as soon as the DDOS attack is detected.

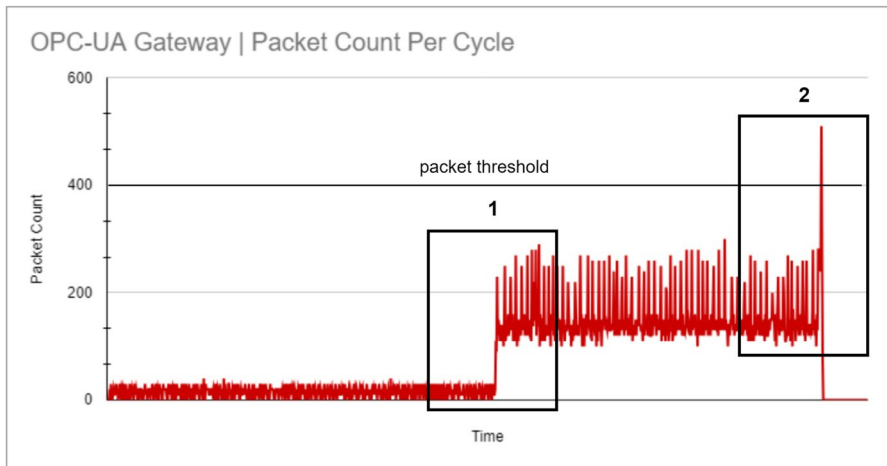


Fig. 8 Data traffic through OPC-UA gateway

Honeypot strategy To demonstrate the honeypot strategy, we integrated a honeypot server (HPS) alongside the existing components in the network topology of the Factory Industry 4.0 presented in Section 3. The HPS is logically integrated into the security toolbox of SOAR4BC via a custom Python script for the Ryu-SDN controller. This script empowers the Ryu controller to add new flow rules to switches, manage packet forwarding actions, and oversee communication between switches and the controller. This modification facilitates the redirection of DDoS traffic to the HPS for analysis upon detection of a DDoS attack. The updated architecture enhances the SOAR4BC system’s ability to detect and mitigate DDoS attacks.

Our experiment begins with the simulation of normal traffic within the Mininet environment to validate the detection capabilities of our SOAR4BC system. We ensure that normal traffic is accurately identified, with no false positives for DDoS attacks. Subsequently, we deliberately initiate a DDoS attack simulation from a designated host (DPS with IP 10.0.0.6) to the MQTT gateway (with IP 10.0.0.1) using the hping3 network tool.⁸ We adopt a classification-based approach to identify DDoS attacks by categorizing network traffic into normal and abnormal categories based on characteristic values extracted from data packets. These values, obtained at specific time intervals, form sequences labelled as either normal or abnormal. To build our detection model, we utilize ML algorithms such as SVM. SVM learns from labelled sequences to classify unlabeled samples, enabling the SOAR4BC system to discern whether incoming traffic signals a potential DDoS attack. Once the attack is correctly identified, the *Adaptation Strategy* (cf. Section 4.2) is notified. Following, the data on the system’s state is used by the DRL agent to devise the best-suited adaptation. This information is then processed into a CACAO-compatible playbook and forwarded to

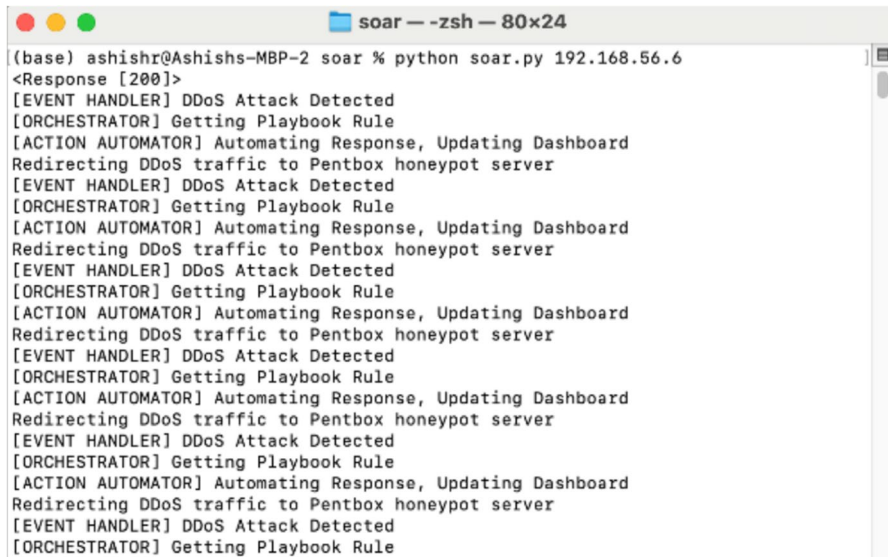
⁸ <https://www.kali.org/tools/hping3/>

the Orchestration Unit. As expected, the inspection terminal in the SOAR4BC system promptly identified the DDoS attack, as shown in Fig. 9, triggering the redirection of traffic to the HPS for further analysis by security operation centres (SOC) with SOC personnel. In this case, the action space involves a human-in-the-loop for the corresponding workflow in the security playbook. This means that the SOC personnel are alerted and can decide whether or not and when to trigger the honeypot strategy. For example, if the attack's impact has not reached a threshold, i.e., "spinning up a honeypot server" is currently too expensive.

When the threshold is reached, the SOAR4BC system deploys a honeypot server within the network architecture to scrutinize traffic redirected from detected DDoS attacks. The Pentbox honeypot serves as a decoy to attract and analyze potentially malicious traffic (Technicaldada: Pentbox 2025). Redirecting DDoS traffic to the honeypot allows SOC personnel to observe attacker behaviour without endangering the actual network infrastructure.

Throughout these processes, SOAR4BC generates comprehensive incident reports, providing stakeholders with real-time insights into the scope, severity, and effectiveness of the response. These detailed reports support post-incident analysis and enhance future preparedness, demonstrating the framework's robustness in maintaining the integrity and resilience of critical infrastructure systems.

As shown in Fig. 10, this comprehensive experimental setup, evaluation, and visualization on the dashboard demonstrate the effectiveness of our SOAR4BC framework in detecting and mitigating DDoS attacks within DT environments, offering robust security measures for DT-based CI systems.



```
(base) ashishr@Ashishs-MBP-2 soar % python soar.py 192.168.56.6
<Response [200]>
[EVENT HANDLER] DDoS Attack Detected
[ORCHESTRATOR] Getting Playbook Rule
[ACTION AUTOMATOR] Automating Response, Updating Dashboard
Redirecting DDoS traffic to Pentbox honeypot server
[EVENT HANDLER] DDoS Attack Detected
[ORCHESTRATOR] Getting Playbook Rule
[ACTION AUTOMATOR] Automating Response, Updating Dashboard
Redirecting DDoS traffic to Pentbox honeypot server
[EVENT HANDLER] DDoS Attack Detected
[ORCHESTRATOR] Getting Playbook Rule
[ACTION AUTOMATOR] Automating Response, Updating Dashboard
Redirecting DDoS traffic to Pentbox honeypot server
[EVENT HANDLER] DDoS Attack Detected
[ORCHESTRATOR] Getting Playbook Rule
[ACTION AUTOMATOR] Automating Response, Updating Dashboard
Redirecting DDoS traffic to Pentbox honeypot server
[EVENT HANDLER] DDoS Attack Detected
[ORCHESTRATOR] Getting Playbook Rule
[ACTION AUTOMATOR] Automating Response, Updating Dashboard
Redirecting DDoS traffic to Pentbox honeypot server
[EVENT HANDLER] DDoS Attack Detected
[ORCHESTRATOR] Getting Playbook Rule
```

Fig. 9 Inspecting for DDoS attack and subsequent response orchestration

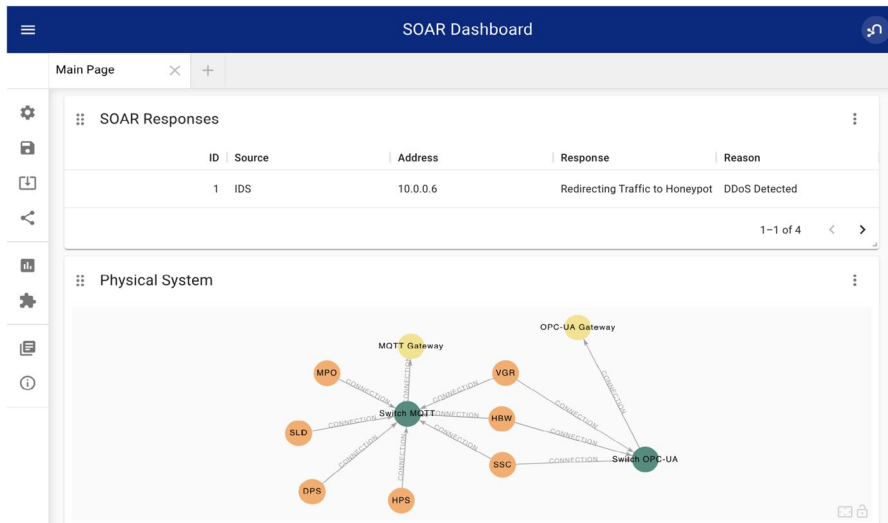


Fig. 10 SOAR4BC dashboard for DDoS attack incident visualisation and response

5.2 EV charging infrastructure

For the second experiment, we replicate an EV charging infrastructure comprised of EV charging stations (EVCS) and the Charging Station Management System (CSMS). The EV charging infrastructure is depicted in Fig. 11. In the field, real EVCSs are employed, which are used by EV users for charging. On the cloud, the CSMS is a web-based platform that utilises the Open Charge Point Protocol (OCPP) to manage the EVCSs and perform various operations on them, including the authorization, management, and billing of charging transactions, health monitoring of EVCSs, log collection, as well as the installation of charging profiles, which adjust the power that an EVCS can consume. Moreover, the EVCS simulator⁹ is also hosted on the cloud, which aims to emulate OCPP-compatible EVCS, allowing the conduction of automated tests on the CSMS and testing on a staging environment.

The CSMS and other components are hosted on a cloud environment running the Proxmox Virtual Environment (VE) operating system. Proxmox VE leverages Open vSwitch for network connectivity between the VMs and the physical world. To enhance security and granular control over network access, for some of the virtual switches (indicated as virtual bridges - vbr), OpenFlow is utilised along with the Ryu SDN Controller for controlling their datapath. We enabled OpenFlow on vbr66 for this experiment, as depicted in Fig. 11. Moreover, a custom OCPP detector is placed on a VM that receives mirrored traffic from vbr1, thus being able to monitor all EVCS network traffic. Detection results are delivered to the Wazuh Security Information and Event Management (SIEM) system, which SOAR4BC can then consume to trigger the relevant incident response strategy.

⁹<https://github.com/sap/e-mobility-charging-stations-simulator>

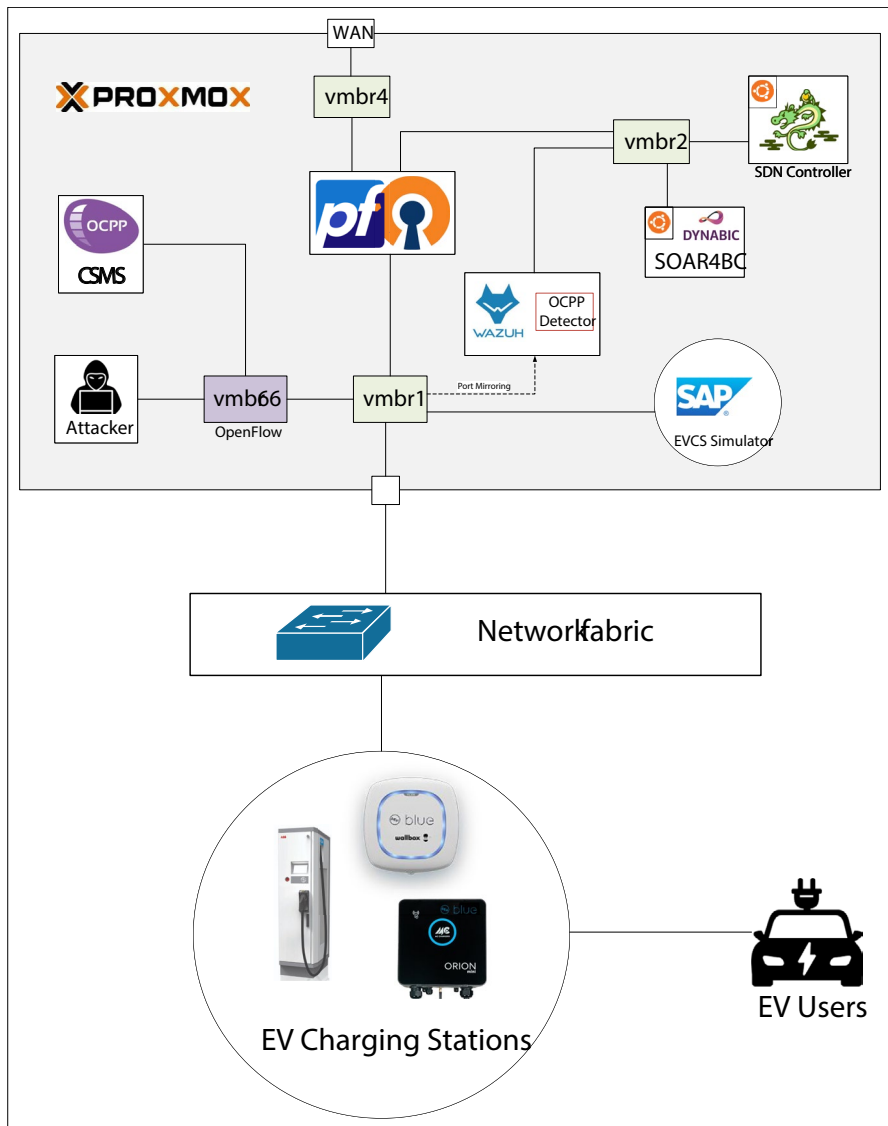


Fig. 11 EVCS network topology

For enabling SOAR4BC, more specifically the *Adaptation Strategy* component (cf. sec. 4.2), we model three competing business goals, revenue, availability, and image, each having its own sub-reward function. *Image* reward is calculated by averaging $1 - \text{declined_transactions} / \text{request_transactions}$ for all relevant OCPP flows. *Availability* reward is calculated by averaging $\text{user_messages} / \text{server_responses}$ for all relevant OCPP flows. Notably, *Image* is only concerned with canceled or declined charging transactions, while *Availability* is concerned with all possible user request messages. Lastly, *Revenue* reward is trivially calculated by subtract-

ing relevant costs, $1 - \text{running_costs} - \text{action_costs}$ where running_costs can be caused, for example, by a running honeypot server and action costs are one-time costs of a given action, e.g., spinning up the honeypot server. All sub-rewards are later added together for a single reward used to train the DRL.

The action space consists of (1) doing nothing, (2) blocking IP(s) via the firewall, (3) blocking IP(s) via Software Defined Networking (SDN) controller, (4) spinning up a honeypot server, (5) shutting down the running honeypot server, and (6) resetting charging profiles. Inconsistent actions, e.g., shutting down a honeypot server if there is no running server, are prohibited.

In order to calculate the above-mentioned rewards, we require the relevant observations. These stem from the observed OCPP traffic, which is then loaded into our state. Additionally, we also require system data, e.g., if a honeypot server is running.

For evaluating the reliability and correctness of Chat4XAI, we follow the proposed metrics by the authors, stability and fidelity (Metzger et al. 2023) and for the responsiveness of the Adaptation Generation, we measure the time to recommendation (cf. Section 5.2.2).

In this experiment, we address the response to two cyberattacks, namely a) False Data Injection and b) Denial of Service (DoS).

5.2.1 False data injection attack

In this scenario, we focus on the resilience of EV charging infrastructure against false data injection attacks that can alter charging profiles and potentially overload the electrical grid. Our setup replicates an EV charging hub, encompassing multiple EVCSs managed by a CSMS.

In this attack, charging profiles are transmitted from the CSMS to the EVCS in the form of OCPP `SetChargingSchedule.req` commands, where the attacker may alter the limit value that corresponds to the maximum power that the EVCSs can consume.

The OCPP Detector monitors the network traffic and generates security events on a rule basis, upon detecting abnormal values on the OCPP commands (e.g., unusually high charging profile limits) that could indicate false data injections. The security events are collected by the Wazuh SIEM, which generates security alerts.

Upon the Wazuh SIEM raises a security alert concerning a false data injection attack, SOAR4BC responds by implementing the playbook generated for this incident based on the pre-defined action space. Here, it reacts by disabling communication from the compromised host, isolating the threat, and preventing further compromise. Furthermore, it can also utilise the REST API of the CSMS to reset the charging profiles of the EVCSs.

SOAR4BC detects unexpected data alteration anomalies indicating potential false data injection due to policy violations in OPA. The system verifies data integrity and assesses deviations when an anomaly is flagged. It orchestrates remediation steps based on the latest playbook, isolating affected components to prevent further false data injection attacks and facilitate a thorough investigation.

As shown in Fig. 12, SOAR4BC provides real-time updates to its dashboard, offering stakeholders clear visibility into incidents and their resolutions. By integrat-

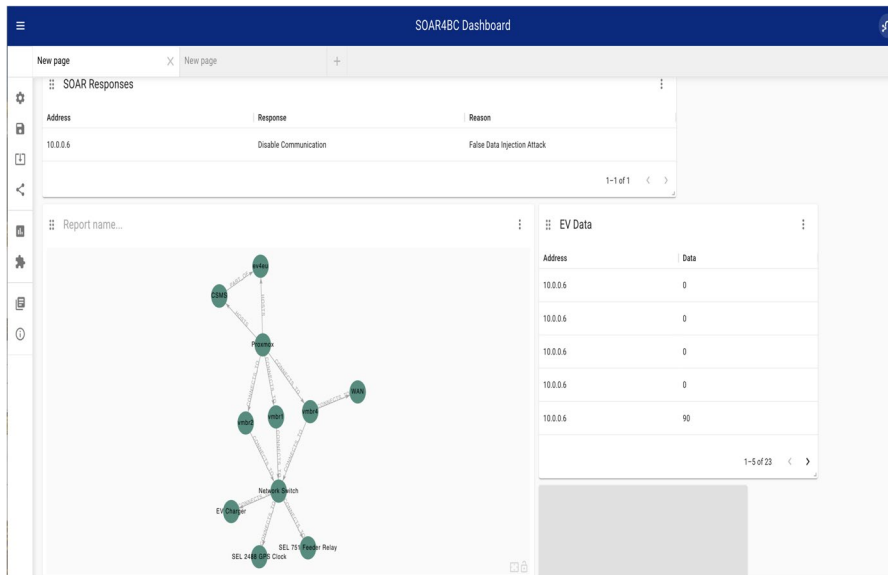


Fig. 12 SOAR4BC dashboard for false data injection attack and orchestrating response

ing detection, response automation, and dashboard updates, SOAR4BC empowers organizations to effectively combat such false data injection attacks and confidently safeguard their critical infrastructure.

This comprehensive SOAR4BC approach ensures that EV charging infrastructure remains resilient against sophisticated cyber threats, maintaining the integrity and reliability of the electric grid.

5.2.2 DoS attack

In this subsection, we detail the Denial of Service (DoS) attack conducted on our real-world EV charging station testbed. SOAR4BC's response to the DoS attack is divided into three distinct sub-scenarios, which are explained below. The CACAO playbook for the three sub-scenarios are shown in Figs. 13, 14, and 15, respectively.

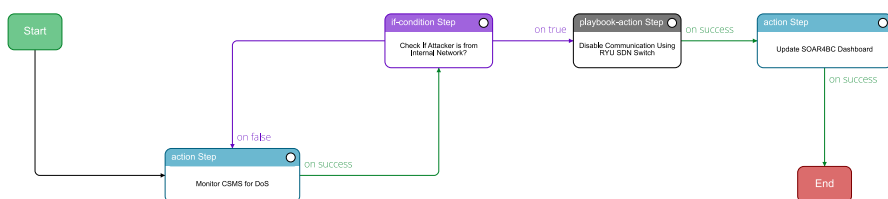


Fig. 13 Blocking internal attacker through Ryu SDN Switch CACAO Playbook for EVCS network

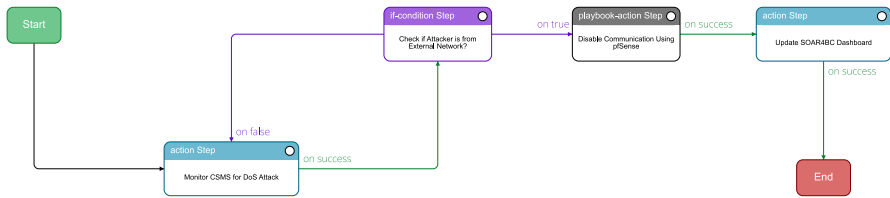


Fig. 14 Blocking external attacker through pfSense CACAO Playbook for EVCS network

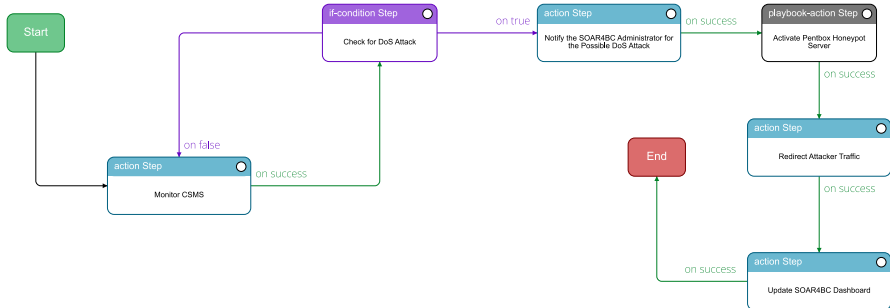


Fig. 15 Honeypot strategy CACAO Playbook for EVCS network

Subscenario 1: blocking local network attackers using SDN controller in EVCS network If the attacker originates from the same local network, their traffic does not traverse external firewalls. In this case, the optimal approach is to block the attack at the SDN switch itself, using the Ryu SDN controller’s firewall API. By blocking the malicious IP at the switch level, we prevent the attack traffic from further penetrating the internal EVCS network and reaching critical services.

As shown in Fig. 16, when a potential DoS attack is detected on the CSMS of EVCS Network, the SOAR4BC system triggers an orchestration process. A playbook is dynamically generated that outlines the appropriate response, i.e., blocking the attacker’s IP address at the SDN switch. Upon receiving this playbook, the orchestrator communicates with the Action Automator, which uses the Ryu SDN controller’s REST API to inject flow rules that block the attacker’s traffic at the switch level. In particular, the Action Automator is responsible for interfacing with the Ryu SDN controller. It programs a flow entry on the controller that blocks traffic from the attacker’s IP address. This function sends the attacker’s IP to the Ryu controller via REST API, which subsequently installs a flow rule to drop all packets originating from that IP. Once the “Block IP Action” is executed, the result is logged into the SOAR4BC dashboard. The attacker IP, action taken (“Blocked at SDN switch”), and reason (“Potential DoS Detected Against CSMS”) are recorded in the SOAR4BC dashboard shown in Fig. 17. Additionally, a timestamp of the action is included for tracking purposes.

```

ashishr — user@soar4bc-sdnc: ~ — ssh user@10.250.100.50 — 80x24
(base) user@soar4bc-sdnc:~$ sudo /home/user/miniconda3/bin/python soar4bc.py
[sudo] password for user:
* Serving Flask app 'soar4bc'
* Debug mode: off
WARNING: This is a development server. Do not use it in a production deployment.
Use a production WSGI server instead.
* Running on http://localhost:5005
Press CTRL+C to quit
[EVENT HANDLER] Potential Denial of Service (DoS) attack against CSMS detected.
[ORCHESTRATOR] Getting Playbook Rule
[ACTION AUTOMATOR] Automating response as per playbook
Sending the following firewall rule to the Ryu controller: {
  "nw_src": "10.250.100.55/32",
  "priority": 1,
  "actions": "DENY"
}
Response from Ryu: 200 - [{"switch_id": "0000e6b563e54042", "command_result": [{"
  "result": "success", "details": "Rule added. : rule_id=1"}]}]
Successfully blocked attacker 10.250.100.55 on switch 0000e6b563e54042.
Updating Dashboard
Neo4J dashboard updated successfully at 2024-10-11 16:07:08

ashishr — user@soar4bc-sdnc: ~/DDoSDN — ssh user@10.250.100.50 — 80x24
(ryu-venv) (base) user@soar4bc-sdnc:~/DDoSDN$ ryu-manager ryu.app.rest_firewall
loading app ryu.app.rest_firewall
loading app ryu.controller.ofp_handler
instantiating app None of DPSet
creating context dpset
creating context wsgi
instantiating app ryu.app.rest_firewall of RestFirewallAPI
instantiating app ryu.controller.ofp_handler of OFPHandler
(857595) wsgi starting up on http://0.0.0.0:8080
[FW][INFO] dpid=0000e6b563e54042: Join as firewall.
(857595) accepted ('127.0.0.1', 60436)
127.0.0.1 - - [11/Oct/2024 14:07:07] "POST /firewall/rules/0000e6b563e54042 HTTP
/1.1" 200 249 0.005584

```

Fig. 16 Subscenario 1: SOAR4BC Inspecting CSMS for DoS attack and subsequent response orchestration

SOAR4BC Dashboard

+

SOAR4BC Response

Address

Response

Reason

Time

10.250.100.55

Block Attacker IP by Ryu SDN

Potential DoS Detected Against CSMS

2024-10-11 16:07:08

1-1 of 1

<

>

Attacker Node Status

Address

Status

Time

10.250.100.55

Blocked

2024-10-11 16:07:08

1-1 of 1

<

>

Fig. 17 Subscenario 1: response visualization dashboard

Subscenario 2: blocking external network attackers using firewall in EVCS network When the attacker originates from an external network, it is possible to block them either on the SDN switch (via the SDN controller REST API) or on the pfSense firewall. However, generally, it is more efficient to block the attacker at the pfSense

firewall, as this prevents unnecessary resource consumption on internal network components, including the SDN switch.

Blocking at the pfSense firewall provides a twofold advantage. First, by blocking malicious traffic at the firewall, we prevent it from entering the internal EVCS network, which could otherwise consume bandwidth and processing power on the SDN switches and internal services. In addition, blocking at the firewall lowers the burden on internal network components, such as switches and servers, which could otherwise be overwhelmed by resource-intensive traffic patterns like Distributed DoS attacks.

Upon detecting external traffic that fits the DoS pattern in the EVCS network, the SOAR4BC orchestrator searches for the actions suitable for external attacks in the dynamically generated playbook. The playbook advises, e.g., blocking the attacker's IP using the pfSense firewall API as shown in Fig. 18. Similar to Subscenario 1, the Action Automator is called in by the SOAR4BC orchestrator and then executes the response. The Action Automator here interacts with the pfSense firewall. It sends an API call to pfSense to add a new rule that blocks all traffic from the attacker's IP. This action ensures that the attacker's IP is blocked by the pfSense firewall.

After the block rule is successfully added on pfSense, the SOAR4BC dashboard is updated with relevant details. The attacker's IP, the response taken ("Blocked at pfSense firewall"), and the common reason ("Potential DoS Detected Against CSMS") are visualized as shown in Fig. 19. This enables security administrators to track how external attackers are handled.

Subscenario 3: redirecting malicious attacker traffic to a honeypot For more advanced handling of attacks, particularly when dealing with persistent or highly distributed threats, one of the efficient ways is to redirect malicious traffic to honeypots. Specifically, in this scenario, the malicious attacker traffic is redirected to a honeypot server instead of simply blocking the attack. The honeypot acts as a decoy system designed to lure attackers into thinking they are interacting with the target system (CSMS). This approach is particularly useful for gathering intelligence about the attack while mitigating the threat by diverting the malicious traffic.

```
(base) user@soar4bc-sdnc:~$ sudo /home/user/miniconda3/bin/python soar4bc.py
* Serving Flask app 'soar4bc'
* Debug mode: off
WARNING: This is a development server. Do not use it in a production deployment.
Use a production WSGI server instead.
* Running on http://localhost:5005
Press CTRL+C to quit
[EVENT HANDLER] Potential Denial of Service (DoS) attack against CSMS detected.
[ORCHESTRATOR] Getting Playbook Rule
[ACTION AUTOMATOR] Blocking IP 10.250.100.55 by pfsense
Response from pfsense: 200
Updating Dashboard
Neo4J dashboard updated successfully at 2024-10-11 15:20:12
```

Fig. 18 Subscenario 2: SOAR4BC inspecting CSMS for external network attackers (DoS Attack) and subsequent response orchestration

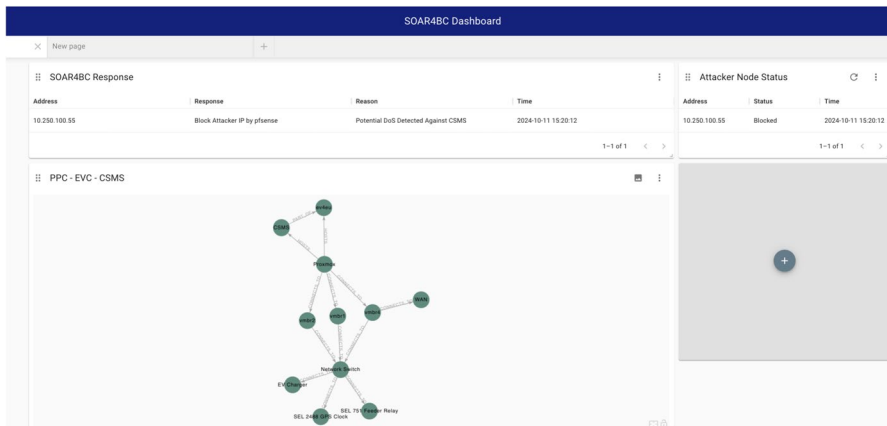


Fig. 19 Subscenario 2: response visualization dashboard

This approach has several advantages. In particular, attackers believe they are successfully targeting a real system, but in reality, they are interacting with an isolated, monitored environment. By diverting malicious traffic to honeypots, critical services like CSMS remain operational and unimpacted by the attack. Moreover, honeypots allow security teams to observe attacker behavior, techniques, and tools, which can provide valuable insights for improving future defenses.

When a DoS attack is detected, the SOAR4BC orchestration process waits for input from the dynamically generated playbook, which instructs the system to start a honeypot server (such as pentbox) and redirects the attacker's traffic to it. The Action Automator executes the playbook action by first alerting the SOAR4BC administrator for the possible DoS attack in the network, which then starts the Pentbox honeypot service and redirects the attacker's traffic to the honeypot as shown in Fig. 20. By doing so, the attacker is led to believe that they are interacting with the CSMS while, in reality, they are interacting with a decoy server. This setup helps administrators

```
(base) user@soar4bc-sdnc:~$ sudo /home/user/miniconda3/bin/python soar4bc.py |
* Serving Flask app 'soar4bc'
* Debug mode: off
WARNING: This is a development server. Do not use it in a production deployment.
Use a production WSGI server instead.
* Running on http://localhost:5005
Press CTRL+C to quit
[EVENT HANDLER] Potential Denial of Service (DoS) attack against CSMS detected.
[ORCHESTRATOR] Getting Playbook Rule

Pentbox Honeypot is now running on port 80 in a detached screen session.
Checking processes listening on port 80:

COMMAND  PID USER  FD  TYPE  DEVICE SIZE/OFF  NODE NAME
ruby     842656 root    5u  IPv4  2796531    0t0  TCP *:http (LISTEN)
Pentbox honeypot server started successfully.
Redirecting traffic from 10.250.100.55 to Pentbox honeypot.
Neo4J dashboard updated successfully at 2024-10-11 15:25:44
```

Fig. 20 Subscenario 3: SOAR4BC Inspecting CSMS for DoS attack and honeypot strategy

observe the attacker's tactics, tools, and procedures in a safe environment by ensuring the malicious requests no longer reach the intended CSMS target but instead are captured by the pentbox honeypot for further analysis.

After the pentbox honeypot is started and traffic is successfully redirected, the SOAR4BC dashboard is updated to reflect the action. This involves logging the attacker's IP, the response taken ("Starting Pentbox Honeypot" and "Redirect traffic to honeypot"), and the reason ("Potential DoS Detected Against CSMS"). These actions are timestamped, ensuring detailed tracking as shown in Fig. 21.

Validating this real-world use case, we also measured the timely overhead that is added by SOAR4BC. We measured two distinct time spans: (i) time to recommendation as $time_{playbook_generated} - time_{triggering_event}$ and (ii) isolation time as $time_{component_isolation_completed} - time_{triggering_event}$. With $n=30$ repetitions, the time to recommendation averages less than 13 seconds, and isolation time was measured as less than 10 seconds. Concerning scaling the use case complexity, e.g., increasing the possible number of adaptation workflows or workflow complexity, should increase the time overhead. However, seeing the current performance, we do not expect the timely performance to be a pressing issue.

To complement our above evaluation, we introduce quantitative metrics as shown in Table 1 aligned with industrial Key Performance Indicators (KPIs). These KPIs originate from the operational requirements of the participating industrial use cases, and our experimental results confirm that SOAR4BC meets or exceeds the required thresholds of the following KPIs.

- KPI 1 - SOAR Network Protection: Number of attempted intrusions successfully stopped at the network perimeter. Result: 97%, demonstrating high effectiveness of the detection, filtering, and blocking mechanisms.
- KPI 2 - SOAR Isolation Time: Time from the initial incident indication to the completion of component isolation. Result: 9.05 seconds, meeting the required response-speed threshold for real-time mitigation.
- KPI 3 - SOAR Recovery Time: Average time required to restore affected components after containment. Result: 4 seconds, indicating minimal operational disruption and an efficient recovery workflow.

SOAR4BC Dashboard			
+			
SOAR4BC Response			
Address	Response	Reason	Time
10.250.100.55	Start Pentbox Honeypot and Redirect Attacker Traffic	Potential DoS Detected Against CSMS	2024-10-11 15:25:44
1-1 of 1 < >			
Attacker Node Status			
Address	Status	Time	
10.250.100.55	Redirecting Traffic	2024-10-11 15:25:44	
1-1 of 1 < >			

Fig. 21 Subscenario 3: response visualization dashboard

Table 1 Key Performance Indicators (KPIs) for SOAR4BC

KPI	Description	Result
KPI 1: SOAR Network Protection	Number of attempted intrusions successfully stopped at the network perimeter.	0.97 (97%)
KPI 2: SOAR Isolation Time	Time from the initial incident indication to the completion of component isolation.	9.05 seconds
KPI 3: SOAR Recovery Time	Average time required to restore affected components after containment.	4 seconds
KPI 4: SOAR Isolation Coverage	Proportion of critical system components that can be selectively isolated without requiring full-system shutdown.	0.9997
KPI 5: Adaptation Strategy Time to Recommendation	Time from triggering event until a playbook is generated.	12.41 seconds
KPI 6: Chat4XAI Fidelity	Percentage of factually correct explanations.	0.8 (80%)
KPI 7: Chat4XAI Stability	Degree to which same answers are given to the same inputs.	0.85 (85%)

- KPI 4 - SOAR Isolation Coverage: Proportion of critical system components that can be selectively isolated without full-system shutdown. Result: 0.9997, showing that SOAR4BC supports near-complete selective isolation of critical assets.
- KPI 5 - Adaptation Strategy Time to Recommendation: Time from triggering event until a playbook is generated. Result: 12.41 seconds, showing that SOAR4BC supports real time threat mitigation.
- KPI 6 - Chat4XAI Fidelity: Percentage of factually correct explanations. Result: 0.8 (80%), indicating trustworthy explanations.
- KPI 7 - Chat4XAI Stability: Degree to which same answers are given to the same inputs. Result: 0.85 (85%), indicating reliable explanations.

5.2.3 Feedback assessment

This section presents an evaluation of early feedback on the SOAR4BC approach, as outlined in Section 4. To gather meaningful insights, we conducted a demonstration of SOAR4BC with a group of expert security and e-mobility operators, utilizing our prototype developed for the *EV charging infrastructure experiment* (see Section 5.2). The feedback assessment is structured to address the following research questions¹⁰:

RQ1: *Do expert security operators understand the SOAR4BC approach?* First, our objective is to assess whether the participants in our demonstration understand SOAR4BC. This ensures that the feedback collected through the following questions is reliable.

¹⁰The full questionnaire and raw data can be found online: uclue.de/Opxr3

RQ2 & RQ3: *How do expert security operators perceive (RQ2) the usefulness and (RQ3) ease of use of SOAR4BC, and what factors influence these perceptions?* Next, we are interested in the experts' opinions and feedback on SOAR4BC, and its provided explanations. Since the Chat4XAI component of SOAR4BC has already been evaluated with respect to its fidelity and stability (Metzger et al. 2023), we now focus on how experts perceive (RQ2) the usefulness of SOAR4BC and (RQ3) the ease of use of its explainability capabilities.

RQ4: *Would expert security operators trust SOAR4BC?* To successfully operate critical infrastructures (CIs), it is essential that the security operator trusts automation tools like SOAR4BC. First, we are interested in whether expert security operators would trust an application like SOAR4BC, which enables automated decision-making. Secondly, we want to identify the role of explanations in fostering that trust.

RQ5: *What are the identified limitations and areas for improvement?* Finally, our objective is to assess potential improvements and identify limitations. We ask the expert security operators to describe in their own words potential improvements, expected features, and current limitations.

Design We design the feedback assessment session to be divided into three parts. First, we present the SOAR4BC approach using slides, emphasizing the motivation behind SOAR4BC and detailing its capabilities. Next, we demonstrate SOAR4BC and its explainability feature through a live demonstration following the scenario described in Section 5.2. During this demonstration, we share our screens to display both the SOAR4BC dashboard and the Chat4XAI interface. Expert security operators are able to engage with Chat4XAI as a group, asking questions verbally and in writing, which will then be posed to Chat4XAI by the webinar leaders. Finally, expert security operators are asked to complete a questionnaire to provide their feedback. All rating questions follow a five-point Likert scale (i.e., *extremely unlikely, quite unlikely, neither, quite likely, extremely likely*). We use a verbal scale with negative to positive options to receive more “conservative” results as suggested by Metzger and Cassales Marquezan (2011).

To assess perceived usefulness and perceived ease of use (RQ2 & RQ3), we draw on the Technology Acceptance Model (TAM) (Davis 1989). TAM has become a de facto standard for analyzing technology acceptance (Marangunić and Granić 2015). Its advantages include low complexity, empirically validated measurement scales, and robustness (King and He 2006; Morris and Dillon 1997). Studies have also demonstrated TAM's effectiveness in evaluating software prototypes (Morris and Dillon 1997; Laitenberger and Dreyer 1998; Davis and Venkatesh 2004).

As suggested by Vogelsang et al. (2013), we complement the standardized TAM questionnaire with open-ended questions. This approach offers the advantage of additionally considering the context and correlations of the factors influencing participants' ratings (Vogelsang et al. 2013). Thus, we ask rating questions followed by an open-ended question after each rating, asking the expert security operators for the reason on their rating (i.e., “Please explain [...] why you selected the rating for statement [id]?”). Since we are only interested in the participants' perceived usefulness

and *perceived ease of use* of SOAR4BC, we do not take into account other variables of TAM such as the *attitude towards using* or the *behavioural intention to use*.

To analyze the results, we adopt a qualitative approach, as our goal is to gather mid-development feedback to identify general acceptance, areas for improvement, and additional insights into user perceptions. Since we do not intend to conduct a comprehensive study during this development stage, we invite only a small group of experts to participate, which limits the reliability of a quantitative analysis.

Execution We conduct the feedback assessment as a webinar session using Microsoft Teams, inviting a small group of experts from the e-mobility and cybersecurity sectors. The questionnaire is built with Google Forms and is shared within the webinar session. Participants are asked to fill out the questionnaire right after the webinar session.

Results The feedback assessment was conducted on Friday, October 11, 2024. We present aggregated results according to the research questions, with the full results available online.¹¹ Moreover, we also present the feedback assessment into a Table 2 summarizing the key strengths and weaknesses identified by the expert operators. The results for **RQ1** indicate that expert security operators were able to understand the concept of SOAR4BC after our presentation and live demonstration. However, due to the limited scope of the live demonstration, the experts expressed some uncertainty regarding whether additional incident types could be detected, whether multi-step workflows are supported, and whether integration with security tools other than Wazuh is available. Regarding **RQ2**, all experts perceive SOAR4BC as a useful tool. In particular, automated decision-making during an incident or attack is seen as a way to improve both efficiency (i.e., completing tasks faster) and effectiveness (i.e., completing tasks with fewer errors) in the daily work of a security operator. Furthermore, the experts emphasize that SOAR4BC reduces the risk of human error during incidents, provided that the created playbooks are accurate. The security operator can use the additional time gained to focus on communication with other parties during an incident, ensuring, for example, that personal data is untouched while SOAR4BC secures critical infrastructure. When assessing **RQ3**, i.e., the perceived ease of use of SOAR4BC's explainability capabilities, i.e., Chat4XAI, the expert security operators suggest providing predefined questions along with the possibility to ask open-ended questions. On the one hand, the operation of Chat4XAI was perceived to be easy because its interface is similar to popular (GenAI) chatbot interfaces, such as ChatGPT. On the other hand, in the special case of being a security operator who wants to understand the decision-making of an AI agent, inexperienced users might not know which questions to ask. We recognize providing guidance and/or predefined questions as useful and plan to implement them as future work.

The experts emphasize that having access to explanations of the AI's decision-making process increases trust in the AI's actions (**RQ4**). The ability of SOAR4BC to generate explanations for its decision-making was therefore rated positively. Without

¹¹udue.de/IMAIV

Table 2 Summary of expert feedback on SOAR4BC (Strengths vs. Weaknesses)

Research Question	Identified Strengths	Identified Weaknesses / Improvement Needs
RQ1: Understanding of SOAR4BC	Clear understanding of the SOAR4BC concept after presentation and demo.	Limited clarity on detection of additional incident types and support for complex multi-step workflows.
RQ2: Perceived Usefulness	Seen as highly useful for improving efficiency and effectiveness during security incidents, reduces human error, frees operator time for communication and supervisory tasks.	Accuracy of automated playbooks must be ensured, usefulness depends on correct integration with additional security tools.
RQ3: Perceived Ease of Use (Explainability)	Chat4XAI interface familiar to users due to similarity to modern chatbot tools, explanations help operators understand decisions.	Experts request predefined/templated questions to assist inexperienced users, independent exploration of explanations was limited during demo.
RQ4: Trust in SOAR4BC	Explanations significantly increase trust in automated decisions, transparency is valued by all participants.	Without explanations, trust decreases substantially, real-world validation needed for stronger confidence.
RQ5: Limitations & Areas for Improvement	Appreciation for the concept and potential of SOAR4BC, positive reception of automation and explainability.	Need for enhanced dashboard summaries (KPI widgets), quicker access to explanations, broader mitigation options, proactive defense, and automation of repetitive tasks, human oversight must remain central.

access to such explanations, the expert security operators indicated that they would adopt a more neutral stance regarding their trust in applications like SOAR4BC.

As potential improvements (**RQ5**), the expert security operators suggest enhancing the SOAR4BC dashboard with widgets that summarize selected KPIs, providing faster access to explanations (e.g., through predefined questions), and supporting a broader range of mitigation actions as well as a proactive defense against attacks. The experts also expressed a desire for SOAR4BC to handle repetitive tasks, such as IP blocking and ticket creation. However, they emphasize that maintaining human oversight in the decision-making process remains of utmost importance.

Discussion The feedback assessment yielded promising insights regarding the SOAR4BC approach, demonstrating an overall positive reception from expert secu-

riety and e-mobility operators, particularly concerning the perceived usefulness, ease of use, and trustworthiness of the tool. However, further development, field testing, and validation are needed.

While the feedback assessment provided valuable insights, it has some limitations. The small sample size limits generalizability, as the feedback reflects views from a specific group of expert operators, which introduces potential biases. A broader user base could offer more diverse perspectives and additional user needs. Additionally, the chosen demonstration format may have influenced responses, as operators could not independently explore all SOAR4BC features. Lastly, technical challenges encountered during the live demonstration of SOAR4BC and its explainability component Chat4XAI potentially influenced the assessment results, particularly since participants could not interact with explanations on live data. However, the participants still expressed an appreciation for the explanations provided. This feedback underscores the importance of explainability in promoting trust, as noted in RQ4, for CI operators.

In summary, the feedback assessment offers a valuable basis for refining SOAR4BC, highlighting positive impacts on operator efficiency, decision accuracy, and trust in AI-driven actions. The insights gained provide clear directions for future development and enhancements, particularly in user guidance, interface refinement, and expanding functionality in the SOAR4BC dashboard. While the results are limited in scope and may include potential biases, the findings support the SOAR4BC as an effective tool for CIs.

6 Related works

6.1 SOAR related-work

Bellavista et al. focus on reducing technological barriers by providing the IoTwins platform, which leverages the Digital Twin (DT) computing paradigm along with ICT technologies such as Cloud/Edge computing, Big Data, and Machine Learning (Bellavista and Di Modica 2024). The IoTwins platform facilitates the development and operation of industrial applications by offering a hybrid and distributed DT model. This model involves various industrial partners to validate and refine the DT, where SOAR functionality can be deployed and tested in real-world settings.

Islam et al. present an architecture-centric approach for designing a SOAR platform, highlighting key dimensions of the architecture design space (Islam et al. 2020). Their work reduces the design complexity of a SOAR system by modularizing its functionalities and non-functional requirements. The architecture is divided into six layers: (1) security tool, (2) integration, (3) data processing, (4) semantic, (5) orchestration, and (6) User Interface (UI). This layered approach facilitates understanding and analyzing design choices. Based on their architectural approach, they conclude with a Proof of Concept (PoC) SOAR platform.

Empl et al. discuss SOAR4IoT, focusing on securing IoT assets using DTs (Empl et al. 2022). They address challenges in securing IoT devices due to their hetero-

geneity and inadequate security measures. Their work integrates the SOAR platform to benefit from tool integration, automation, streamlined workflows, and rapid responses. DTs are utilized for additional response measures, where live data from DT solutions enhance security measures for IoT devices.

Bartwal et al. introduce a SOAR Engine designed to enhance infrastructure security by dynamically deploying custom honeypots based on attacker behavior (Bartwal et al. 2022). This approach engages attackers longer, conserves resources, and increases interaction with honeypots to gather organization-specific threat intelligence. Their system demonstrated improved attacker engagement, resource savings, and effective detection of malicious samples and DDoS traffic, showcasing its effectiveness in protecting internal networks.

Allison et al. explore using DTs to support cybersecurity incident response in CPSs (Allison et al. 2023). They discuss applying DTs throughout the Incident Response (IR) Life Cycle, categorizing previous research based on IR phases and digital twin modes of operation. The authors propose integrating DTs into IR playbooks to enhance the effectiveness and efficiency of incident response activities. By analyzing existing IR workflows and identifying the most suitable digital twin forms for different tasks, they highlight the potential of data-driven DTs for anomaly detection, system monitoring, and the use of simulations for system intervention activities.

Recent research highlights the persistent delays in incident response, with organizations often taking 63 days to detect data breaches and an additional 20 days to respond, underscoring the need for faster, more efficient solutions (Nguyen et al. 2024). While SOAR platforms aim to automate the identification and mitigation of threats, they face critical limitations. These include the complexity of managing playbooks, the inflexibility of hard-coded responses, and the shortcomings of rule-based methods that struggle to adapt to evolving threats. To address these issues, AI4SOAR is introduced in Nguyen et al. (2024), which leverages similarity learning techniques to streamline playbook management. However, despite its success against SSH brute-force attacks, AI4SOAR has yet to fully integrate advanced AI capabilities. The AI4SOAR system still relies on predefined methods rather than harnessing AI's full potential for dynamic, real-time decision-making. This highlights the need for further refinement of AI integration in SOAR solutions to address critical incident response capabilities. A recent systematic review has been more specific to analyse the research landscape of SOAR approaches applicable for IoT/CPS/computing continuum to identify gaps in the research for IoT/CPS-based multi-layered critical systems. It shows that DTs remain largely unexplored within SOAR implementations, but getting more attention lately (Allison et al. 2023; Empl and Pernul 2023; Nguyen et al. 2024; Alskaif et al. 2025; Suhail et al. 2025). The exploration of using DTs for supporting cyber security is reported in Allison et al. (2023). Even though the approach of cyber security incident response is not a SOAR approach but it shows how different modalities of DT use can be applied to the phases of cyber security incident response, enhancing cyber security playbooks. Another attempt to make use of DT for cyber security is the DT2SA model (Empl and Pernul 2023) that aligns security analytics with digital twins to generate shareable cybersecurity knowledge. More recently, an approach for security-enhancing digital twins has been reported in Suhail et al. (2025) and demonstrated using a cyber-physical production system use

case. Similar to Allison et al. (2023), Empl and Pernul (2023), this approach does not have a real SOAR approach but rather mixing different security purposes such as risk assessment, intrusion detection, cyber deception. In other words, these recent DT-based approaches show the attempts of leveraging DTs for cyber security but not really security orchestration.

While these works contribute significantly to the fields of DTs and SOAR, they highlight gaps and opportunities for further integration and enhancement. Current solutions often address specific aspects of security orchestration and response or focus on particular technologies. However, they do not fully leverage the combined potential of DTs and SOAR capabilities, as well as AI-driven adaptation.

To address these challenges, our proposed SOAR4BC framework integrates contextual insights from DTs with security intelligence from various tools, adopting a holistic approach to security orchestration. Our SOAR4BC approach aims to provide comprehensive protection, enhance resource utilization, and minimize latency by leveraging edge computing capabilities, thereby advancing the state-of-the-art in securing CI systems. Moreover, the explainability of the response decision devised in the playbook generated by the DRL agent has been empowered by the Chat4XAI module, which we discuss the related work in the next subsection. Our complementary work that provides more DT-based explainability for ML-based security services as part of security orchestration has been presented in Nguyen et al. (2024). The existing SOAR approaches focus on either SOAR or DT, but do not integrate explainability and AI-driven adaptation as SOAR4BC does, leveraging Explainable RL as discussed in the next section.

6.2 Explainable RL-related work

There exists a plethora of different RL algorithms, each providing benefits and disadvantages. More recently, Deep RL (DRL) has become the de facto standard. A well-established value-based approach, Double Deep Q-Networks (DDQN) with experience replay, holds the benefit of reward decomposition over policy-based approaches (Sutton and Barto 1998; Arulkumaran et al. 2017; Feit et al. 2022). DRL was successfully applied to a spectrum of different problems (Huang et al. 2022; Iftikhar et al. 2023; Jamil et al. 2022; Mutanu and Kotonya 2019; Razian et al. 2022; Yu et al. 2022) including SOC (Anderson et al. 2024; Mareedu 2025; Noshi and Blaser 2024). However, it is insufficient to consider only DRL SOTA, but also its natural language explainability. Despite comprehensive evaluations of DRL performance within various system applications (Ma and Xu 2023; Huang et al. 2022; Mo et al. 2021; Ghanadbashi et al. 2023), the task of elucidating DRL decision-making processes through natural language remains mostly unattended. In the realm of explainable AI (XAI), endeavors have been dedicated to furnishing natural-language explanations for machine learning (Kuřba and Biecek 2020; Liao et al. 2020; Nguyen et al. 2022; Malandri et al. 2023). Nonetheless, these methodologies predominantly concentrate on supervised learning paradigms and rely on conventional dialogue systems (Motger et al. 2023), necessitating preliminary question solicitation and definition. Recent advancements, commencing in 2023, have witnessed a substantial integration of Large Language Models (LLMs) (Zhao et al. 2023) in XAI, notably

within the domain of explainable recommendations (Dave et al. 2024; Widyasari et al. 2024; Ali and Kostakos 2023; Wu et al. 2024), as well as broader XAI applications (Wang et al. 2023; Ghosh and Sadaphal 2023; Gao et al. 2023; Chu et al. 2024). Research in the XAI field can be categorized into three principal domains (i) Requirements Elicitation (ii) Design and Realization (iii) LLM-based XAI: **Requirements Elicitation** Jentzsch et al. (2019), Kuźba and Biecek (2020), Liao et al. (2020), Gao et al. (2023) All these works provide interesting insights into what questions may be asked but are limited to supervised learning. Leveraging LLMs to answer arbitrary messages removes the need for requirement elicitation altogether. **Design and Realization** Carneiro et al. (2021), Nguyen et al. (2022), Malandri et al. (2023) All these works provide evidence for the benefits of using natural-language explanations. However, they do not deliver explanations for Deep RL. Also, they are all built using classical dialogue systems and natural language processing and thus do not leverage the capabilities of modern large language models. **LLM-based (XAI)** Dave et al. (2024) and Widyasari et al. (2024) have showcased the effectiveness of Large Language Models (LLMs) in generating natural language explanations tailored for fault detection applications. Similarly, Ali and Kostakos (2023) employ established XAI tools like SHAP and LIME in conjunction with GPT-3.5 as an LLM to provide insights and explanations for network anomaly detection alerts. In a broader context, Wu et al. (2024) have outlined various strategies for leveraging LLMs to advance XAI, presenting abstract frameworks and methodologies for LLM-based XAI. Notably, certain aspects, such as recognized prompting patterns, have been operationalized in Chat4XAI (Metzger et al. 2023). Wang et al. (2023) introduce LLM4Vis, a system utilizing ChatGPT to offer explainable visualization recommendations. By integrating LLMs with visualization techniques, the system facilitates intuitive and interpretable recommendations to users. Ghosh and Sadaphal (2023) present a framework for generating explainable job recommendations by incorporating LLMs. By harnessing the natural language capabilities of LLMs, the system enhances user understanding and trust in job recommendations, thereby contributing to improved decision-making in career transitions. Gao et al. propose Chat-rec (Gao et al. 2023), an interactive and explainable recommender system augmented with LLMs. The system enhances transparency and user engagement by integrating LLMs into the recommendation process and enabling user interaction, leading to more effective and personalized recommendations. Additionally, Chu et al. (2024) introduce a novel LLM-guided multi-view hypergraph learning approach to generate human-centric and explainable recommendations. The proposed method provides personalized and interpretable recommendations tailored to individual user preferences and needs by combining LLMs with multi-view hypergraph learning techniques.

It is noteworthy that while these methodologies and insights offer valuable contributions to XAI, their direct applicability to the domain of (D)RL is limited. Explanation techniques suitable for supervised learning, such as LIME and SHAP, do not translate effectively to (D)RL scenarios due to differing assumptions and domain characteristics.

DRL in cyber security Deep Reinforcement Learning (DRL) has been applied to various cyber security problems (Nguyen and Reddi 2023). Nguyen and Reddi (2023)

provides an extensive survey on how DRL has been used in cyber security with a special emphasis on cyber-physical systems (CPS). They structure the application fields in detection, cyber-physical systems and game theory. Papers categorized in cyber-physical systems tackling defense strategies are closely related to our approach. Feng and Xu (2017) approached the CPS defense challenge by framing it as a two-player zero-sum game between attackers and defenders. In this setup, DRL, specifically actor-critic algorithms, enables the defender to learn optimal strategies to counteract unknown cyber-attacks. Similarly, Akazaki et al. (2018) utilized DRL techniques such as DDQN and A3C to identify defects in CPS models by discovering falsified inputs. These DRL methods proved more effective than traditional approaches like simulated annealing and cross-entropy in efficiently detecting issues within CPS models. Our approach differs from the related work, as we follow a holistic approach using a digital twin, a more sophisticated SOAR and also consider the SecDevOps flow. Secondly, we apply SOAR4BC to critical infrastructures, focusing on the human-in-the-loop paradigm for defensive mechanisms and resilience measures.

7 Conclusions and future work

Our study has underscored the critical importance of addressing cybersecurity concerns in the digitization of critical infrastructures (CI). We have introduced an AI-driven security orchestration automation and response framework leveraging digital twin-provided holistic security and system context (SOAR4BC). Designed to detect and orchestrate security responses and analyses, this framework ensures robust security measures for safeguarding the integrity of DT-based systems. Through rigorous experimental evaluation, focusing on false data injection and distributed denial of service (DDoS) attacks, we demonstrated the efficacy and reliability of the SOAR4BC framework for conducting security orchestration, automation and response leveraging a deep reinforcement learning approach, the standardized CACAO playbook version 2, and the different security tools as well as the DT of the physical system. Additionally, our experiments on a real-world EV Testbed validate the SOAR4BC framework's practical applicability and effectiveness in protecting CI systems. Our findings provide compelling evidence of the SOAR4BC framework's effectiveness, serving as a proof of concept for its practical application in addressing cybersecurity threats in DT-based critical infrastructures.

For future work, As CI becomes increasingly interconnected through technologies such as the Internet of Things (IoT) and Cyber-Physical Systems (CPS), coupled with the adoption of the Digital Twin (DT) paradigm, the vulnerability to cyber threats escalates. The distributed and heterogeneous nature of CI presents formidable challenges in mitigating diverse attack surfaces, while the potential for cascading effects amplifies the complexity of the security landscape. Our SOAR4BC approach has shown an AI-driven SOAR framework leveraging digital twin-provided holistic security and system context, which is evaluated using diverse-but-still-limited attack scenarios. Even though we have attempted to address some cascading effects of cross-domain CIs in the later phase of the DYNABIC project, this line of work should be followed up to be more mature.

By leveraging the advanced natural language processing and understanding capabilities of Large Language Models (LLMs), we can augment the framework's ability to analyze and interpret complex security-related data to address the evolving security threats and potential cascading effects from cyber attacks. On the other hand, we plan to enable the continuous integration and continuous deployment (CI/CD) of security mechanisms or system components as part of SOAR4BC based on our previous work (Ferry et al. 2020; Ferry and Nguyen 2019; Ferry et al. 2019) to better support SecDevOps. This CI/CD support ensures that robust security measures can be deployed as part of (preventive) SOAR4BC approach throughout the lifecycle of DT-based CI systems, mitigating security risks at every stage of development and operation.

Acknowledgements The research leading to this publication has received funding from the European Union Research and Innovation Programme under the Grant Agreement 101070455 - DYNABIC and 101225858 – SECASSURED. Views and opinions expressed are, however, those of the authors only and do not necessarily reflect those of the European Union. Neither the European Union nor the granting authority can be held responsible for them. We thank the external experts, Christina Boura and Ioannis Papadopoulos from PPC, who joined the evaluation session and provided feedback by answering the questionnaires. It should be noted that the external experts expressed their own professional views during the survey, which do not necessarily reflect the views of the PPC Group.

Author Contributions Conceptualization, P.N., A.R., J.B. and K.P.; Methodology, P.N., A.R., and J.B.; Software Implementation and Experiments, P.N. A.R., J.B.; Formal Analysis, A.R., J.B., and C.D.; Validation, A.R., J.B., J.L. and C.D.; Writing - Original Draft Preparation, P.N. A.R., and J.B.; Writing - Review and Editing, P.N., A.R., J.B., J.L., C.D., and K.P.; Visualization, P.N., A.R.; Supervision, P.N., A.R., J.B. and K.P.; Project Administration, P.N., J.B., and K.P.; Funding Acquisition, P.N., A.R., J.B., and K.P. All authors reviewed the manuscript.

Funding Open access funding provided by SINTEF.

Data Availability No datasets were generated or analysed during the current study.

Declarations

Competing interests The authors declare no competing interests.

Ethics approval and consent to participate This article does not contain any studies with human participants or animals performed by any of the authors.

Open Access This article is licensed under a Creative Commons Attribution 4.0 International License, which permits use, sharing, adaptation, distribution and reproduction in any medium or format, as long as you give appropriate credit to the original author(s) and the source, provide a link to the Creative Commons licence, and indicate if changes were made. The images or other third party material in this article are included in the article's Creative Commons licence, unless indicated otherwise in a credit line to the material. If material is not included in the article's Creative Commons licence and your intended use is not permitted by statutory regulation or exceeds the permitted use, you will need to obtain permission directly from the copyright holder. To view a copy of this licence, visit <http://creativecommons.org/licenses/by/4.0/>.

References

- Akazaki, T., Liu, S., Yamagata, Y., Duan, Y., Hao, J.: Falsification of cyber-physical systems using deep reinforcement learning. In: Formal Methods: 22nd International Symposium, FM 2018, Held as Part of the Federated Logic Conference, FloC 2018, Oxford, UK, July 15–17, 2018, Proceedings 22, pp. 456–465 (2018). Springer
- Alcaraz, C., Lopez, J.: Digital twin: A comprehensive survey of security threats. *IEEE Commun. Surv. & Tutor.* **24**(3), 1475–1503 (2022)
- Ali, T., Kostakos, P.: Huntgpt: Integrating machine learning-based anomaly detection and explainable ai with large language models (llms). *arXiv preprint [arXiv:2309.16021](https://arxiv.org/abs/2309.16021)* (2023)
- Allison, D., Smith, P., McLaughlin, K.: Digital twin-enhanced incident response for cyber-physical systems. In: Proceedings of the 18th International Conference on Availability, Reliability and Security, pp. 1–10 (2023)
- Allison, D., Smith, P., McLaughlin, K.: Digital twin-enhanced incident response for cyber-physical systems. In: Proceedings of the 18th International Conference on Availability, Reliability and Security. ARES '23. Association for Computing Machinery, New York, NY, USA (2023). <https://doi.org/10.1145/3600160.3600195>
- Alskaf, T., Babur, Ö., Bordeleau, F., Cleophas, L., Combemale, B., Denil, J., Haugen, Ø., Michael, J., Nguyen, P., Secleanu, T., et al.: Evolution at the core of digital twin engineering (2025)
- Alwarafy, A., Al-Thelaya, K.A., Abdallah, M., Schneider, J., Hamdi, M.: A survey on security and privacy issues in edge-computing-assisted internet of things. *IEEE Internet Things J.* **8**(6), 4004–4022 (2020)
- Anderson, R.L., Harrison, E.K., Collins, M.D., Ramirez, S.J., Yusuff, M.: AI-Driven Orchestration of Multi-Cloud Security Responses (2024)
- Arulkumaran, K., Deisenroth, M.P., Brundage, M., Bharath, A.A.: A brief survey of deep reinforcement learning. *arXiv preprint [arXiv:1708.05866](https://arxiv.org/abs/1708.05866)* (2017)
- Bartwal, U., Mukhopadhyay, S., Negi, R., Shukla, S.: Security orchestration, automation, and response engine for deployment of behavioural honeypots. In: 2022 IEEE Conference on Dependable and Secure Computing (DSC), pp. 1–8 (2022)
- Bellavista, P., Di Modica, G.: Iotwins: Implementing distributed and hybrid digital twins in industrial manufacturing and facility management settings. *Future Int.* **16**(2), 65 (2024)
- Bharatee, A., Ray, P.K., Subudhi, B., Ghosh, A.: Power management strategies in a hybrid energy storage system integrated ac/dc microgrid: A review. *Energies* **15**(19) (2022). <https://doi.org/10.3390/en15197176>
- Carneiro, D., Veloso, P., Guimarães, M., Baptista, J., Sousa, M.: A conversational interface for interacting with machine learning models. In: XAILA@ ICAIL. CEUR Workshop Proceedings, vol. 3168. CEUR-WS.org, Aachen, Germany (2021)
- Chowdhury, N., Gkioulos, V.: Cyber security training for critical infrastructure protection: A literature review. *Comput. Sci. Rev.* **40**, 100361 (2021)
- Chu, Z., Wang, Y., Cui, Q., Li, L., Chen, W., Li, S., Qin, Z., Ren, K.: Llm-guided multi-view hypergraph learning for human-centric explainable recommendation. *arXiv preprint [arXiv:2401.08217](https://arxiv.org/abs/2401.08217)* (2024)
- Dave, A.J., Nguyen, T.N., Vilim, R.B.: Integrating llms for explainable fault diagnosis in complex systems. *arXiv preprint [arXiv:2402.06695](https://arxiv.org/abs/2402.06695)* (2024)
- Davis, F.D.: Perceived usefulness, perceived ease of use, and user acceptance of information technology. *MIS Quarterly*, 319–340 (1989)
- Davis, F.D., Venkatesh, V.: Toward preprototype user acceptance testing of new information systems: implications for software project management. *IEEE Trans. Eng. Manage.* **51**(1), 31–46 (2004)
- Empl, P., Pernul, G.: Digital-twin-based security analytics for the internet of things. *Information* **14**(2) (2023). <https://doi.org/10.3390/info14020095>
- Empl, P., Schlette, D., Zupfer, D., Pernul, G.: Soar4iot: securing iot assets with digital twins. In: Proceedings of the 17th International Conference on Availability, Reliability and Security, pp. 1–10 (2022)
- Feit, F., Metzger, A., Pohl, K.: Explaining Online Reinforcement Learning Decisions of Self-Adaptive Systems. *arxiv:2210.05931* (2022)
- Feng, M., Xu, H.: Deep reinforcement learning based optimal defense for cyber-physical system in presence of unknown cyber-attack. In: 2017 IEEE Symposium Series on Computational Intelligence (SSCI), pp. 1–8 (2017). IEEE

- Ferry, N., Nguyen, P., Song, H., Novac, P.-E., Lavirotte, S., Tigli, J.-Y., Solberg, A.: Genesis: Continuous orchestration and deployment of smart iot systems. In: 2019 IEEE 43rd Annual Computer Software and Applications Conference (COMPSAC), vol. 1, pp. 870–875 (2019). <https://doi.org/10.1109/CO MPSAC.2019.00127>
- Ferry, N., Nguyen, P.H., Song, H., Rios, E., Iturbe, E., Martinez, S., Rego, A.: Continuous deployment of trustworthy smart iot systems. *J. Object Technol.*, **19**(2) (2020)
- Ferry, N., Nguyen, P.H.: Towards model-based continuous deployment of secure iot systems. In: 2019 ACM/IEEE 22nd International Conference on Model Driven Engineering Languages and Systems Companion (MODELS-C), pp. 613–618 (2019). <https://doi.org/10.1109/MODELS-C.2019.00093>
- Fischertechnik: Training factory industry 4.0 24V. <https://www.fischertechnik.de/en/products/industry-and-universities/training-models/554868-training-factory-industry-4-0-24v>. Accessed 16 June 2025
- Gao, Y., Sheng, T., Xiang, Y., Xiong, Y., Wang, H., Zhang, J.: Chat-rec: Towards interactive and explainable llms-augmented recommender system. *arXiv preprint arXiv:2303.14524* (2023)
- Ghanadhashi, S., Safavifar, Z., Taebi, F., Golpayegani, F.: Handling uncertainty in self-adaptive systems: an ontology-based reinforcement learning model. *J. Reliable Intell. Environ.*, (2023)
- Ghosh, P., Sadaphal, V.: Jobrecogpt-explainable job recommendations using llms. *arXiv preprint arXiv:2309.11805* (2023)
- Huang, V., Wang, C., Ma, H., Chen, G., Christopher, K.: Cost-aware dynamic multi-workflow scheduling in cloud data center using evolutionary reinforcement learning. In: *Service-Oriented Computing - ICSOC 2022*, pp. 449–464. Springer, Seville, Spain (2022)
- Iftikhar, S. et al.: AI-based fog and edge computing: A systematic review, taxonomy and future directions. *Internet Things* **21** (2023)
- Isaja, M., Nguyen, P., Goknil, A., Sen, S., Husom, E.J., Tverdal, S., Anand, A., Jiang, Y., Pedersen, K.J., Myrseth, P., et al.: A blockchain-based framework for trusted quality data sharing towards zero-defect manufacturing. *Comput. Ind.* **146**, 103853 (2023)
- Islam, C., Babar, M.A., Nepal, S.: A multi-vocal review of security orchestration. *ACM Comput. Surv.* **52**(2) (2019). <https://doi.org/10.1145/3305268>
- Islam, C., Babar, M.A., Nepal, S.: Architecture-centric support for integrating security tools in a security orchestration platform. In: Jansen, A., Malavolta, I., Muccini, H., Ozkaya, I., Zimmermann, O. (eds.) *Software Architecture*, pp. 165–181. Springer, Cham (2020)
- Islam, C., Babar, M.A., Nepal, S.: Architecture-centric support for integrating security tools in a security orchestration platform. In: *Software Architecture: 14th European Conference, ECSA 2020, L'Aquila, Italy, September 14–18, 2020, Proceedings 14*, pp. 165–181 (2020). Springer
- Jamil, B., Ijaz, H., Shojafar, M., Munir, K., Buyya, R.: Resource allocation and task scheduling in fog computing and internet of everything environments: A taxonomy, review, and future directions. *ACM Comput. Surv.* **54**(11s) (2022)
- Jentsch, S.F., Höhn, S., Hochgeschwender, N.: Conversational interfaces for explainable ai: a human-centred approach. In: *International Workshop on Explainable, Transparent Autonomous Agents and Multi-agent Systems*, pp. 77–92 (2019). Springer
- Jordan, B., Thomson, A.: CACAO Security Playbooks Version 2.0, OASIS Committee Specification 01. <https://docs.oasis-open.org/cacao/security-playbooks/v2.0/security-playbooks-v2.0.html>. Accessed: 15 Jul 2025
- King, W.R., He, J.: A meta-analysis of the technology acceptance model. *Inf. Manag.* **43**(6), 740–755 (2006)
- Kuzba, M., Biecek, P.: What would you ask the machine learning model? identification of user needs for model explanations based on human-model conversations. In: *Joint European Conference on Machine Learning and Knowledge Discovery in Databases*, pp. 447–459 (2020). Springer
- Laitenberger, O., Dreyer, H.M.: Evaluating the usefulness and the ease of use of a web-based inspection data collection tool. In: *Proceedings Fifth International Software Metrics Symposium. Metrics (Cat. No. 98TB100262)*, pp. 122–132 (1998). IEEE
- Liao, Q.V., Gruen, D., Miller, S.: Questioning the ai: informing design practices for explainable ai user experiences. In: *Proceedings of the 2020 CHI Conference on Human Factors in Computing Systems*, pp. 1–15 (2020)
- Ma, W., Xu, H.: Skyline-enhanced deep reinforcement learning approach for energy-efficient and qos-guaranteed multi-cloud service composition. *Appl. Sci.* **13**(11) (2023)
- Malandri, L., Mercorio, F., Mezzanzanica, M., Nobani, N.: Convxai: a system for multimodal interaction with any black-box explainer. *Cogn. Comput.* **15**(2), 613–644 (2023)

- Marangunić, N., Granić, A.: Technology acceptance model: a literature review from 1986 to 2013. *Univ. Access Inf. Soc.* **14**(1), 81–95 (2015)
- Mareedu, A.: Autonomous security operations centers (soc): Ai agents for threat triage, response, and orchestration. *Int. J. Emerging Res. Eng. Technol.* **6**(2), 63–70 (2025). <https://doi.org/10.63282/3050-922X.IJERET-V6I2P108>
- Metzger, A., Bartel, J., Laufer, J.: An ai chatbot for explaining deep reinforcement learning decisions of service-oriented systems. In: *International Conference on Service-Oriented Computing*, pp. 323–338 (2023). Springer
- Metzger, A., Bartel, J., Laufer, J.: An ai chatbot for explaining deep reinforcement learning decisions of service-oriented systems. In: Monti, F., Rinderle-Ma, S., Ruiz Cortés, A., Zheng, Z., Mecella, M. (eds.) *Service-Oriented Computing*, pp. 323–338. Springer, Cham (2023b)
- Metzger, A., Cassales Marquezan, C.: Future internet apps: The next wave of adaptive service-oriented systems? In: *European Conference on a Service-Based Internet*, pp. 230–241 (2011). Springer
- Microsoft Security: What is SOAR? <https://www.microsoft.com/en-us/security/business/security-101/what-is-soar>. Accessed 16 June 2025
- Mo, R., Xu, X., Zhang, X., Qi, L., Liu, Q.: Computation offloading and resource management for energy and cost trade-offs with deep reinforcement learning in mobile edge computing. In: *International Conference on Service-Oriented Computing*, pp. 563–577 (2021). Springer
- Morris, M.G., Dillon, A.: How user perceptions influence software use. *IEEE Softw.* **14**(4), 58–65 (1997)
- Motger, Q., Franch, X., Marco, J.: Software-based dialogue systems: Survey, taxonomy, and challenges. *ACM Comput. Surv.* **55**(5) (2023)
- Mutanu, L., Kotonya, G.: State of runtime adaptation in service-oriented systems: what, where, when, how and right. *IET Softw.* **13**(1), 14–24 (2019)
- Neupane, K., Haddad, R., Chen, L.: Next generation firewall for network security: A survey. In: *Southeast-Con 2018*, pp. 1–6 (2018). <https://doi.org/10.1109/SECON.2018.8478973>
- Nguyen, P., Dautov, R., Song, H., Rego, A., Iturbe, E., Rios, E., Sagasti, D., Nicolas, G., Valdés, V., Mallouli, W., Cavalli, A., Ferry, N.: Towards smarter security orchestration and automatic response for cps and iot. In: *2023 IEEE International Conference on Cloud Computing Technology and Science (CloudCom)*, pp. 298–302 (2023). <https://doi.org/10.1109/CloudCom59040.2023.00055>
- Nguyen, M.-T., Lam, A.N., Nguyen, P., Truong, H.-L.: Security orchestration with explainability for digital twins-based smart systems. In: *2024 IEEE 48th Annual Computers, Software, and Applications Conference (COMPSAC)*, pp. 1194–1203 (2024). <https://doi.org/10.1109/COMPSAC61105.2024.0159>
- Nguyen, M.-D., Mallouli, W., Cavalli, A.R., Oca, E.: Ai4soar: A security intelligence tool for automated incident response. In: *Proceedings of the 19th International Conference on Availability, Reliability and Security. ARES '24. Association for Computing Machinery, New York, NY, USA* (2024). <https://doi.org/10.1145/3664476.3670450>
- Nguyen, P.H., Rauniyar, A., Niemi, T.V.: Digital twin-based security orchestration, automation and response for iot and cps. In: Rey, G., Tigli, J.-Y., Franquet, E. (eds.) *Internet of Things*, pp. 243–260. Springer, Cham (2025)
- Nguyen, V.B., Schlötterer, J., Seifert, C.: Explaining machine learning models in natural conversations: Towards a conversational XAI agent. *arXiv:2209.02552* (2022)
- Nguyen, P., Song, H., Dautov, R., Ferry, N., Rego, A., Rios, E., Iturbe, E., Valdes, V., Cavalli, A.R., Mallouli, W.: Knowledge systematization for security orchestration in cps and iot systems. In: *2025 IEEE International Conference on Cyber Security and Resilience (CSR)*, pp. 672–678 (2025). <https://doi.org/10.1109/CSR64739.2025.11130008>
- Nguyen, T.T., Reddi, V.J.: Deep reinforcement learning for cyber security. *IEEE Trans. Neural Netw. Learn. Syst.* **34**(8), 3779–3795 (2023). <https://doi.org/10.1109/TNNLS.2021.3121870>
- Noshi, A., Blaser, F.: Integrating artificial intelligence and machine learning for advanced cyber security in SOC operations (2024). <https://doi.org/10.13140/RG.2.2.21176.05121>
- Pellissier Tanon, T., Weikum, G., Suchanek, F.: Yago 4: A reason-able knowledge base. In: *The Semantic Web: 17th International Conference, ESWC 2020, Heraklion, Crete, Greece, May 31–June 4, 2020, Proceedings 17*, pp. 583–596 (2020). Springer
- Rajmohan, T., Nguyen, P.H., Ferry, N.: A decade of research on patterns and architectures for iot security. *Cybersecurity* **5**(1), 2 (2022)
- Razian, M.R., Fathian, M., Bahsoon, R., Toosi, A.N., Buyya, R.: Service composition in dynamic environments: A systematic review and future directions. *J. Syst. Softw.* **188**, 111290 (2022)

- Riggs, H., Tufail, S., Parvez, I., Tariq, M., Khan, M.A., Amir, A., Vuda, K.V., Sarwat, A.I.: Impact, vulnerabilities, and mitigation strategies for cyber-secure critical infrastructure. *Sensors* **23**(8), 4060 (2023)
- Rios, E., Iturbe, E., Rego, A., Ferry, N., Tigli, J.-Y., Lavirotte, S., Rocher, G., Nguyen, P., Song, H., Dautov, R., et al.: The dynabic approach to resilience of critical infrastructures. In: *Proceedings of the 18th International Conference on Availability, Reliability and Security*, pp. 1–8 (2023)
- Rios, E., Iturbe, E., Rego, A., Ferry, N., Tigli, J.-Y., Lavirotte, S., Rocher, G., Nguyen, P., Song, H., Dautov, R., Mallouli, W., Cavalli, A.R.: The dynabic approach to resilience of critical infrastructures. In: *Proceedings of the 18th International Conference on Availability, Reliability and Security. ARES '23. Association for Computing Machinery, New York, NY, USA* (2023). <https://doi.org/10.1145/3600160.3605055>
- Sheikh, Z.A., Singh, Y., Singh, P.K., Ghafoor, K.Z.: Intelligent and secure framework for critical infrastructure (cps): Current trends, challenges, and future scope. *Comput. Commun.* **193**, 302–331 (2022)
- Sikos, L.F.: Cybersecurity knowledge graphs. *Knowl. Inf. Syst.*, 1–21 (2023)
- Suhail, S., Iqbal, M., McLaughlin, K., Lee, B., Imtiaz, B.: A framework for enhancing cyber incident response with security-enhancing digital twins in cyber-physical systems. *Internet of Things* **31**, 101547 (2025). <https://doi.org/10.1016/j.iot.2025.101547>
- Sutton, R.S., Barto, A.G.: *Reinforcement learning: An introduction*, 1st edn. MIT Press, Cambridge, MA (1998)
- Technicaldada: Pentbox. <https://github.com/technicaldada/pentbox>. Accessed 16 June 2025
- Tigli, J.-Y., Lavirotte, S., Rey, G., Hourdin, V., Riveill, M.: Context-aware authorization in highly dynamic environments. *arXiv preprint arXiv:1102.5194* (2011)
- Vogelsang, K., Steinhüser, M., Hoppe, U.: A qualitative approach to examine technology acceptance, vol. 1 (2013)
- Vrandečić, D., Krötzsch, M.: Wikidata: a free collaborative knowledgebase. *Commun. ACM* **57**(10), 78–85 (2014)
- Wang, L., Zhang, S., Wang, Y., Lim, E.-P., Wang, Y.: Llm4vis: Explainable visualization recommendation using chatgpt. *arXiv preprint arXiv:2310.07652* (2023)
- Waszak, M., Lam, A.N., Hoffmann, V., Elvesæter, B., Mogos, M.F., Roman, D.: Let the asset decide: digital twins with knowledge graphs. In: *2022 IEEE 19th International Conference on Software Architecture Companion (ICSA-C)*, pp. 35–39 (2022). IEEE
- Widyasari, R., Ang, J.W., Nguyen, T.G., Sharma, N., Lo, D.: Demystifying faulty code with llm: Step-by-step reasoning for explainable fault localization. *arXiv preprint arXiv:2403.10507* (2024)
- Wu, X., Zhao, H., Zhu, Y., Shi, Y., Yang, F., Liu, T., Zhai, X., Yao, W., Li, J., Du, M., et al.: Usable xai: 10 strategies towards exploiting explainability in the llm era. *arXiv preprint arXiv:2403.08946* (2024)
- Yu, Z., Zhao, S., Su, T., Liu, W., Liu, X., Wang, G., Wang, Z., Leung, V.C.: Deepsejd: an online deep learning-based model for secure collaborative job dispatching in edge computing. In: *International Conference on Service-Oriented Computing*, pp. 481–497 (2022). Springer
- Zhao, W.X., Zhou, K., Li, J., Tang, T., Wang, X., Hou, Y., Min, Y., Zhang, B., Zhang, J., Dong, Z., et al.: A survey of large language models. *arXiv preprint arXiv:2303.18223* (2023)

Publisher's Note Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.

Authors and Affiliations

**Phu Nguyen¹ · Ashish Rauniyar¹ · Jone Bartel² · Jan Laufer² ·
Christos Dalamagkas³ · Klaus Pohl²**

✉ Phu Nguyen
phu.nguyen@sintef.no

✉ Ashish Rauniyar
ashish.rauniyar@sintef.no

Jone Bartel
jone.bartel@paluno.uni-due.de

Jan Laufer
jan.laufer@paluno.uni-due.de

Christos Dalamagkas
c.dalamagkas@ppcgroup.com

Klaus Pohl
klaus.pohl@paluno.uni-due.de

¹ Sustainable Communication Technologies, SINTEF, Strindvegen 4, Trondheim 7034, Trøndelag, Norway

² paluno - The Ruhr Institute for Software Technology, University of Duisburg-Essen (UDE), Gerlingstr. 16, Essen 45127, North Rhine-Westphalia, Germany

³ Testing, Research and Standards Centre, Public Power Corporation (PPC), Kantza, Athens 15351, Attica, Greece